Datenschutz-Folgenabschätzung — Entwurf

Stand: 15.10.2026. Entwurf nach Art. 35 DSGVO für die Verarbeitungstätigkeit „KI-gestützte Auswertung von Mandatsakten (jusperfect)".

Wie dieser Entwurf zu lesen ist

Er ist kein Gutachten und keine Rechtsberatung. Er ist das, was die Entwicklung beitragen kann: eine vollständige, belegte Beschreibung dessen, *was* das Programm tut, *welche Risiken* daraus entstehen und *welche Maßnahmen* dagegen im Programm stehen — jede mit Fundstelle.

Die Bewertung bleibt bei der Kanzlei. Ob eine DSFA erforderlich ist, ob das verbleibende Risiko tragbar ist und ob die Aufsichtsbehörde nach Art. 36 einzuschalten ist, kann nur ein Jurist entscheiden, der das Mandatsgeschäft kennt. Diese Stellen sind mit **[KANZLEI n]** gekennzeichnet; es sind **zweiundzwanzig**, und sie stehen in Abschnitt 8 noch einmal in einer Liste.

Zum Stand am 15.10.2026: Zu jeder einzelnen liegt ein ausformulierter Entwurf vor. Sieben sind entschieden oder erledigt (Nr. 6, 7, 13, 18, 19, 20, 21; Nr. 22 bis auf die jährliche Durchsicht). Die übrigen sind zu lesen und zu zeichnen. **Zwei warten auf Dritte** — die Auskunft von AWS zu den Regionen des Geländerprofils (Nr. 11) und die Muss-Liste der Hamburger Aufsichtsbehörde (Nr. 16). **Eines ist noch auszuführen:** die Belehrung an den Auftragsverarbeiter nach § 43e BRAO (Nr. 9); das Schreiben liegt in `BELEHRUNG-AWS.md` bereit.

Erledigte Stellen bleiben stehen und durchgestrichen — eine Stelle, die verschwindet, sieht aus, als hätte es sie nie gegeben.

Die Zahlen und Befunde stehen woanders. Jede technische Angabe hier ist aus `DSFA-ANGABEN.md` übernommen, wo sie mit Datum und Fundstelle steht. Bei Widerspruch gilt `DSFA-ANGABEN.md`.

Dieses Dokument	Was es ist
`DSFA-ENTWURF.md`	diese Datei — Art. 35, Risiken und Maßnahmen
`VERARBEITUNGSVERZEICHNIS-ENTWURF.md`	Art. 30 — die Beschreibung der Verarbeitung
`DSFA-ANGABEN.md`	die gemessenen technischen Werte, mit Datum
`SICHERHEIT.md`	die 16 Grundsätze und das Löschkonzept

---

1. Ist eine DSFA überhaupt erforderlich?

[KANZLEI 1] — die erste und wichtigste Bewertung. Was dafür spricht, aus der Sicht dessen, der das Programm gebaut hat:

Anhaltspunkt	Lage hier
Art. 35 Abs. 3 lit. b — umfangreiche Verarbeitung besonderer Kategorien (Art. 9) oder von Daten über Straftaten (Art. 10)	Trifft je nach Rechtsgebiet regelmäßig zu: Gesundheitsdaten in Unfall-, Arzthaftungs- und Sozialrechtsakten, Art.-10-Daten im Strafrecht. Das Programm unterscheidet **nicht** nach Rechtsgebiet
Neue Technologie (Art. 35 Abs. 1)	Ein Sprachmodell wertet Mandatsakten aus. Das ist für die Kanzlei neu
Berufsgeheimnis	Der verarbeitete Inhalt unterliegt § 203 StGB und § 43a BRAO
Muster-Liste der deutschen Aufsichtsbehörden (DSK)	Dort ist die Verarbeitung von Daten, die einem Berufsgeheimnis unterliegen, durch einen Auftragsverarbeiter aufgeführt. **[KANZLEI 16] — beantwortet, soweit es ohne die Liste selbst geht.** Zuständig ist **Hamburg** (Kanzleisitz Stolper Straße 4, 22145 Hamburg), also die Muss-Liste des **Hamburgischen Beauftragten für Datenschutz und Informationsfreiheit für den nicht-öffentlichen Bereich** (Stand 17.10.2018, Fassung 1.1), abrufbar unter `datenschutz-hamburg.de`. **Ihr Wortlaut liegt nicht vor** — die Seite ist vom Entwicklungsrechner aus nicht erreichbar. Sie ist aufzurufen und auszudrucken; ein Blatt für die Akte
Umfang	Der Bestand umfasst rund 2.950 Akten und etwa 78.000 Dateien (gemessen 02.10.2026). Ob das „umfangreich" im Sinne der Norm ist: **[KANZLEI 2]** — Entwurf unten

Was dagegen sprechen könnte — und ebenfalls bewertet gehört: Es findet keine automatisierte Entscheidung im Sinne des Art. 22 statt, keine Profilbildung, keine systematische Überwachung, und die Verarbeitung dient ausschließlich dem einzelnen Mandat.

> **Ein Hinweis aus der Entwicklung, keine Empfehlung.** Falls die Kanzlei zu dem Ergebnis kommt, dass keine DSFA erforderlich ist, gehört **diese Prüfung selbst** dokumentiert (Rechenschaftspflicht, Art. 5 Abs. 2). Dieser Entwurf taugt dann als Dokumentation der Prüfung.

[KANZLEI 1] — die Bewertung. Entwurf zur Übernahme, geschrieben am 15.10.2026.

> **Zur Erforderlichkeit einer Datenschutz-Folgenabschätzung.** Die Kanzlei hält eine Folgenabschätzung nach Art. 35 DSGVO für erforderlich. Die Verarbeitung erfasst regelmäßig besondere Kategorien personenbezogener Daten (Art. 9) und Daten über strafrechtliche Verurteilungen und Straftaten (Art. 10), sie betrifft durchweg Inhalte, die dem Berufsgeheimnis des § 203 StGB unterliegen, sie bedient sich dafür eines Auftragsverarbeiters und einer für die Kanzlei neuen Technologie. Die Folgenabschätzung wird deshalb durchgeführt, ohne dass es auf die Auslegung einzelner Merkmale ankommt.

Warum ich dazu rate, und zwar ohne Zögern. Drei Gründe, in dieser Reihenfolge:

1. **Die Gegenargumente treffen andere Merkmale.** Dass es keine automatisierte Entscheidung nach Art. 22, keine Profilbildung und keine systematische Überwachung gibt, ist richtig — nur sind das die Merkmale des Art. 35 Abs. 3 lit. a und lit. c. Getragen wird die Pflicht hier von **lit. b**, und den berührt keines dieser Argumente.
2. **Die Kosten sind asymmetrisch.** Eine Folgenabschätzung, die sich später als nicht erforderlich erweist, hat Arbeit gekostet. Eine unterlassene, die erforderlich war, ist ein Verstoß gegen Art. 35 — und sie fällt ausgerechnet dann auf, wenn ohnehin etwas schiefgegangen ist.
3. **Die Unterlage wird ohnehin gebraucht.** Was hier steht, trägt zugleich das Verzeichnis nach Art. 30, die Dienstleisterauswahl nach § 43e Abs. 2 BRAO und die Hinweise nach Art. 13. Der Aufwand ist nicht verloren, auch wenn die Pflicht verneint würde.

[KANZLEI 2] — „umfangreich"? Entwurf zur Übernahme.

> **Zum Merkmal „umfangreich".** Verarbeitet wird der gesamte Aktenbestand der Kanzlei — rund 2.950 Akten und etwa 78.000 Dateien (Stand 02.10.2026) —, fortlaufend, systematisch und ohne Beschränkung auf einzelne Rechtsgebiete. Die Kanzlei sieht das Merkmal als erfüllt an.
>
> **Das Gegenargument, das zu kennen ist. Erwägungsgrund 91** nimmt die Verarbeitung durch „einen einzelnen Arzt, sonstigen Angehörigen eines Gesundheitsberufs oder Rechtsanwalt" ausdrücklich davon aus, als umfangreich zu gelten. Darauf könnte man sich stützen — **aber nur mit Mühe:** Der Erwägungsgrund spricht vom *einzelnen* Berufsträger, und hier geht es um eine Partnerschaftsgesellschaft und um ein Programm, das den ganzen Bestand erfasst.
>
> **Es kommt darauf aber nicht an**, und das ist der eigentliche Grund, es nicht auszufechten: Der Eintrag der Muss-Liste zum Berufsgeheimnis (`[KANZLEI 16]`) trägt die Pflicht unabhängig vom Umfang, und Art. 35 Abs. 1 trägt sie über die neue Technologie ohnehin.

---

2. Systematische Beschreibung der Verarbeitung

Vollständig in `VERARBEITUNGSVERZEICHNIS-ENTWURF.md`. Hier nur, was für die Risikobewertung gebraucht wird.

2.1 Was wohin geht

Schritt	Was verlässt die Kanzlei	Wohin
Dokumente lesen	nichts	—
Gescannte Seite erkennen	**ein Bild je Seite**	AWS Textract, Frankfurt. Verarbeitet; **weder gespeichert noch zur Verbesserung der AWS-KI-Dienste verwendet** — wirksame Abmelderichtlinie seit 14.10.2026, siehe `[KANZLEI 19]`

Schritt	Was verlässt die Kanzlei	Wohin
Frage, Analyse, Entwurf	**die ausgewählten Passagen** als Text	AWS Bedrock, Frankfurt, über das EU-Inferenzprofil. **Nicht zum Training verwendet** (Service Terms 50.12, Stand 15.09.2026) und für das genutzte Modell **auch nicht zur Missbrauchserkennung aufbewahrt** — anders als bei den namentlich gelisteten Modellen, siehe `[KANZLEI 22]`
Schutzgeländer	**Frage und Antwort**, nicht der Akteninhalt	`eu.guardrail.v1:0`, verteilt auf europäische Regionen
Aktengedächtnis sichern	**Dokumenttexte und Abgeleitetes**	S3-Bucket der Kanzlei, Frankfurt, SSE-KMS
Vermerk zurückschreiben	**nur der freigegebene Text**	jur\

Was das Modell nicht zu sehen bekommt: Dokumentkennungen, Nutzerkennungen, Sitzungskennungen. Es sieht Systemanweisung, Passagen und Aufgabe (`providers/bedrock.py`).

> **Berichtigt am 05.10.2026 nach der Zweitprüfung (Befund F11).** Hier stand zusätzlich „Dateinamen" und „Aktenzeichen" — **das war falsch.** Das **Aktenzeichen** steht in der ersten Zeile des Materials, und der **Dokumenttitel** in jeder Passagenüberschrift; liefert jur|nodes keinen Titel, ist das der **Dateiname** (`services/prompts.py`, `jurnodes/http_adapter.py`). Dass dem Anbieter keine gesonderten Metadatenobjekte übergeben werden, verhindert nicht, dass dieselben Angaben als Text mitgehen.
>
> ~~**[KANZLEI 18]** — zu entscheiden: ob dieser Umfang gewollt ist oder ob beides durch neutrale Bezeichnungen zu ersetzen ist.~~
>
> **Entschieden am 05.10.2026** (Grundlage: `F11-VORSCHLAG.md`, dort die Messung an vier Testakten). Seitdem gilt:
>
> *Der Dateiname geht nicht mehr hinaus. Aus dem Titel wird nur noch die Art des Schriftstücks genannt — und auch die als Wort aus einer Liste im Programm, nie als Text aus dem Dateinamen: `Dokument 2 – Kündigung`. Erkennt die Liste nichts, heißt es nur `Dokument 2`. Die Richtung des Irrtums stimmt damit: weniger Auskunft, nie mehr.* **Das Aktenzeichen geht nur noch beim Entwurf mit.** Ein Anschreiben trägt „Unser Zeichen"; Frage, Analyse und Eingangsprüfung brauchen es nicht. *Beteiligte und Kurzrubrum bleiben.** Sie gehen absichtlich hinaus: Das Modell braucht die Rollen — ohne sie hat es im September die gegnerische Kanzlei als Rechtsschutzversicherung geführt —, und dieselben Namen stehen im Dokumenttext ohnehin.
>
> **Anonym ist die Übermittlung dadurch nicht.** Im Dokumenttext stehen weiterhin Namen, Beträge und Daten; das ist der Zweck der Auswertung und in Abschnitt 3.2 bewertet.
>
> Die Oberfläche ist unberührt: Der Dokumenttitel in der Belegkarte und über der Passage kommt aus dem Programm und ging nie durch das Modell.

> `SICHERHEIT.md` enthält dieselbe zu weite Aussage („nie Dateinamen"). Die Datei ist geschützt und wird nur auf ausdrückliche Anweisung geändert.

2.2 Wo dauerhaft gespeichert wird

Seit dem **05.10.2026** besteht eine dauerhafte Kopie von Akteninhalt außerhalb von jur|nodes: das Aktengedächtnis im S3-Bucket der Kanzlei, Frankfurt, verschlüsselt mit einem eigenen KMS-Schlüssel, Objektnamen ohne Aktenzeichen.

Das ist der Umstand, der diese Unterlage auslöst. Vorher war jede Verarbeitung flüchtig.

2.3 Die Rolle des Menschen

Keine Ausgabe des Programms wirkt nach außen, bevor ein Mensch sie freigegeben hat. Das ist nicht nur vorgesehen, sondern technisch gebunden: Die Freigabe ist an Nutzer, Akte, Textprüfsumme und Vorgang gekoppelt (HMAC, `security/approval.py`); ein geänderter Text, eine fremde Akte oder eine nachgebaute Signatur werden abgewiesen (`tests/test_freigabe.py`).

2.4 Verschlüsselung gegenüber dem Auftragsverarbeiter

Ergänzt am 13.10.2026 auf Frage der Kanzlei. Die technische Darstellung steht in `SICHERHEIT.md`, Abschnitt „Verschlüsselung gegenüber AWS"; hier steht, was für die Risikobewertung daraus folgt.

Es ist eine sichere Umgebung mit verschlüsselter Ablage, nicht eine Verschlüsselung, die den Auftragsverarbeiter aussperrt. Diese Unterscheidung trägt mehrere Risiken dieses Abschnitts, und sie wird häufig verwechselt:

	Zustand bei AWS
Übertragung	verschlüsselt (TLS)
Dauerhafte Ablage (S3)	verschlüsselt mit dem KMS-Schlüssel der Kanzlei
Verarbeitung im Modell (Bedrock)	**Klartext**
Verarbeitung in der Texterkennung (Textract)	**Klartext**

Warum die beiden letzten Zeilen nicht anders sein können. Ein Modell muss den Text lesen, um ihn zu beantworten; eine Texterkennung muss das Bild sehen. Verschlüsselter Inhalt ist für beide ohne Nutzen. Es gibt an dieser Stelle keine Bauweise, die es anders macht — auch keine andere Software.

Was der KMS-Schlüssel deshalb bedeutet, und was nicht. Er schützt die Ablage wirksam: Ohne `kms:Decrypt` auf diesen Schlüssel ist kein Objekt lesbar, die Kanzlei verfügt allein über die Schlüsselrichtlinie, kann ihn sperren oder löschen, und jede Entschlüsselung steht in CloudTrail. Er liegt aber **im Dienst KMS bei AWS** — es ist der Schlüssel der Kanzlei, nicht einer, den AWS nie gesehen hat.

> **Daraus folgt für diese Unterlage:** Die Verarbeitung ist **Auftragsverarbeitung** nach Art. 28 DSGVO und **nicht** ein Vorgang, dem durch Verschlüsselung der Personenbezug genommen wäre. Keine Maßnahme dieses Abschnitts darf als „AWS kann den Inhalt nicht lesen" gelesen werden. Wo in dieser Unterlage „verschlüsselt" steht, ist die **Ablage** gemeint.

Die Maßnahme an der offenen Stelle ist Mengenbegrenzung, nicht Verschlüsselung. Zum Modell gehen die Systemanweisung, die **vom Bearbeiter ausgewählten Passagen** und die Aufgabe — nicht die Akte (Abschnitt 2.1, `providers/bedrock.py`). Damit ist die Auswahl im Dokumentfenster die wirksamste Maßnahme in der Hand des Bearbeiters: Was nicht angehakt ist, sieht das Modell nie. Sie ist in Abschnitt 3.3 als Datenminimierung geführt und gehört in die Einweisung.

Was von hier aus nicht belegbar ist. Was AWS vertraglich zusagt, steht nicht im Programm. Belegbar ist nur, *was das Programm sendet und wie es ablegt*. Die Aufbewahrung beim Auftragsverarbeiter hängt am Auftragsverarbeitungsvertrag und — für die KI-Dienste, die sie erfasst — an der **AI-services-Opt-out-Richtlinie**. Sie ist seit dem 14.10.2026 für das Konto wirksam und nachgewiesen (`[KANZLEI 19]`); deshalb sagt die Textract-Zeile in Abschnitt 2.1 wieder „nicht gespeichert". **Für Bedrock gilt das nicht** — die Richtlinienart erfasst es nicht, und dort trägt allein der Auftragsverarbeitungsvertrag.

[KANZLEI 20] — die Entscheidung über die Bauweise

Entschieden am 14.10.2026: Es bleibt bei dieser Bauweise. Die Kanzlei verarbeitet weiterhin mit AWS als Auftragsverarbeiter nach Art. 28 DSGVO und richtet ihre Maßnahmen darauf aus, statt die Verarbeitung auf eigene Hardware zu verlegen.

Worauf sich die Entscheidung stützt. Belegbar ist nur, was das Programm tut; was AWS vertraglich zusagt, steht nicht im Programm (siehe oben).

Umstand	belegt an
Verarbeitung und Ablage in Frankfurt (`eu-central-1`); eine Region außerhalb von EU und EWR lässt das Programm nicht zu, sondern bricht ab	`jusperfect/config.py:118`, `:286`, `:629`
Zum Modell gehen die Systemanweisung, die vom Bearbeiter ausgewählten Passagen und die Aufgabe — **nicht die Akte**	Abschnitt 2.1, `jusperfect/providers/bedrock.py`
Die dauerhafte Ablage ist mit dem KMS-Schlüssel der Kanzlei verschlüsselt; über die Schlüsselrichtlinie verfügt die Kanzlei allein, jede Entschlüsselung steht in CloudTrail	Abschnitt 2.4, `SICHERHEIT.md`
In den Protokollen steht kein Akteninhalt; das ist nicht Vorsatz des Bearbeiters, sondern im Programm erzwungen	`jusperfect/security/protokoll.py`
Der Auftragsverarbeitungsvertrag mit AWS liegt vor und ist Abschnitt für Abschnitt gegen Art. 28 Abs. 3 DSGVO gelesen	Abschnitt 4, R4, „Der Auftragsverarbeitungsvertrag, Abschnitt für Abschnitt"

Was daran Bewertung der Kanzlei ist und kein Beleg: dass diese Mengenbegrenzung, diese Verschlüsselung der Ablage und diese Nachvollziehbarkeit für Unterlagen, die dem Berufsgeheimnis unterliegen (§ 203 StGB), angemessen sind. Das ist eine Abwägung und keine Messung; sie steht der Kanzlei zu und ist hier als ihre Abwägung ausgewiesen.

Was mit dieser Entscheidung ausdrücklich NICHT behauptet wird. Drei Sätze, die aus ihr nicht folgen und an keiner Stelle aus ihr abgeleitet werden dürfen:

1. **Nicht**, dass AWS den Inhalt nicht lesen könne. Bedrock und Textract verarbeiten im Klartext; das lässt sich nicht anders bauen (Abschnitt 2.4).
2. **Nicht**, dass die Alternative geprüft und schlechter befunden worden wäre. Der Preis eigener Hardware an Qualität, Kosten und Betriebsaufwand ist **nicht gemessen** (`[KANZLEI 4]`, Gegenlesung zu Abschnitt 3.2 vom 12.10.2026). Die Entscheidung fällt ohne diese Messung — bewusst, weil die Kanzlei den Aufwand der Messung nicht für verhältnismäßig hält, und nicht, weil das Ergebnis feststünde.
3. **Nicht**, dass die Frage der Speicherung beim Auftragsverarbeiter geklärt wäre. Sie steht als `[KANZLEI 19]` offen.

Unter welcher Bedingung sie gilt. Die Entscheidung setzte voraus, dass `[KANZLEI 19]` eingelöst wird — die wirksame AI-services-Opt-out-Richtlinie für das Konto, nachgewiesen und datiert. **Das ist am selben Tag geschehen** (Abschnitt 4, `[KANZLEI 19]`): die Richtlinie ist am 14.10.2026 um 17:11 MESZ am Konto als wirksam festgestellt und abgelegt. Die Bedingung ist damit erfüllt — für die Dienste, die diese Richtlinienart erfasst. **Für Bedrock ist sie es nicht**, und diese Frage trägt die Entscheidung mit: Sie steht beim AWS-Support und ist bei Antwort hier nachzutragen.

Wann sie neu zu treffen ist. Wenn eines davon eintritt, ist dieser Abschnitt neu zu schreiben und nicht fortzuschreiben:

- `[KANZLEI 19]` lässt sich nicht einlösen — AWS gibt den Nachweis nicht oder nur eingeschränkt;
- AWS ändert die Bedingungen für Bedrock oder Textract in der Region Frankfurt, insbesondere zur Verwendung von Inhalten;
- die Kanzlei verarbeitet mit dem Programm Unterlagen einer Art, die hier nicht bewertet ist;
- es wird eine Bauweise verfügbar, die in der Qualität trägt und ohne Auftragsverarbeiter auskommt — dann ist die Messung nachzuholen, die hier unterblieben ist.

Im Übrigen mit der Unterlage im Ganzen, jährlich.

Festgehalten für die Kanzlei Dortschy & Thunert am 14.10.2026.

Ort, Datum ..... Unterschrift .....

---

3. Notwendigkeit und Verhältnismäßigkeit

[KANZLEI 3] — die Abwägung. Entwurf zur Übernahme, geschrieben am 15.10.2026.

> **Zur Verhältnismäßigkeit.** Der Zweck — die sorgfältige und zügige Bearbeitung des Mandats — ist legitim und deckt sich mit dem Interesse der Mandantschaft. Das Mittel ist geeignet: An einer echten Akte sind aus 55 Dokumenten ein belegter Lebenssachverhalt, ein Zeitstrahl und eine Analyse entstanden, zu Kosten von rund 28 Cent. Es ist erforderlich: Anonymisierung und Pseudonymisierung nehmen der Auswertung ihren Gegenstand, die Beschränkung auf Teile der Akte ist bereits umgesetzt, und ein Modell auf eigener Hardware ist nach heutigem Stand kein gleich wirksames Mittel (`[KANZLEI 4]`). Es ist angemessen, weil der Eingriff durch die Datenminimierung, die Verarbeitung ausschließlich in der Europäischen Union, den Ausschluss jeder Nutzung über die Dienstleistung hinaus, die fortbestehende

> anwaltliche Prüfung und das jederzeitige Ablehnungsrecht der Mandantschaft begrenzt ist. Die Kanzlei hält die Verarbeitung für verhältnismäßig.

Der Satz, auf den es in dieser Abwägung ankommt, ist nicht der von den 28 Cent, sondern der vom Ablehnungsrecht. Eine Verarbeitung, der die Betroffene widersprechen kann, ohne einen Nachteil zu erleiden, ist etwas anderes als eine, der sie ausgeliefert ist — und diese Möglichkeit steht seit dem 15.10.2026 in § 3a der Mandatsbedingungen.

Was die Entwicklung sonst dazu beitragen kann:

3.1 Was die Verarbeitung erreicht

Gemessen an einer echten Akte am 25.09. und 05.10.2026: 55 Dokumente, aus denen ein belegter Lebenssachverhalt, ein Zeitstrahl und eine Analyse entstehen, für rund 28 Cent. Was ein Bearbeiter daran gewinnt, ist Zeit beim Erfassen eines Sachverhalts und das Auffinden von Widersprüchen zwischen Dokument 8 und Dokument 44 — Stellen, die beim Lesen übersehen werden.

3.2 Warum nicht weniger eingriffsintensiv

Mildere Mittel, geprüft	Warum sie nicht reichen
Anonymisierung vor der Übermittlung	Der Gegenstand der Auswertung sind gerade die Personen, Daten und Beträge. Eine Akte, aus der Namen und Daten entfernt sind, beantwortet die Fragen nicht mehr, die gestellt werden
Pseudonymisierung	Dasselbe für Namen; für Beträge, Daten und Sachverhaltsschilderungen nicht durchführbar. Die Kanzlei betreibt mit *Perfect Shield* ein getrenntes Programm für Schwärzungen; es löst eine andere Aufgabe
Nur ein Teil der Akte	Ist umgesetzt: Es geht nur hinaus, was der Bearbeiter anhakt — nicht die Akte je Frage. Seit dem 05.10.2026 kommen Rechnungen und RSV-Korrespondenz schon ohne Haken ins Fenster
Modell auf eigener Hardware	Wäre das mildere Mittel hinsichtlich der Übermittlung. **[KANZLEI 4]** — Entwurf unten. Die Entwicklung kann sagen: technisch möglich, aber mit erheblichem Qualitätsverlust bei den Modellgrößen, die auf Kanzleihardware laufen

[KANZLEI 4] — das Modell auf eigener Hardware. Entwurf zur Übernahme, geschrieben am 15.10.2026.

> **Zum Betrieb eines Modells auf eigener Hardware.** Die Kanzlei hat geprüft, ob die Auswertung auf eigenen Geräten erfolgen kann, und sieht davon nach heutigem Stand ab. Die Modellgrößen, die auf Kanzleihardware lauffähig sind, erreichen die Güte nicht, auf der die Belegpflicht beruht; eine Auswertung, deren Fundstellen weniger verlässlich sind, verlagert das Risiko von der Übermittlung auf die Richtigkeit. Die Entscheidung wird bei der jährlichen Durchsicht erneut geprüft.

Ein Gesichtspunkt, der dabei gern übersehen wird — und er spricht nicht für die eigene Hardware. Ein Modell im eigenen Haus beseitigt die Übermittlung, aber es verlagert die Sicherheit der Verarbeitung von einem Anbieter mit geprüftem Informationssicherheits-

Managementsystem (ISO 27001, SOC 2 Typ 2, Anlagen 7 bis 13) auf die Kanzlei selbst. Ob ein Server im Keller besser geschützt ist als ein Rechenzentrum in Frankfurt, ist keine rhetorische Frage — sie ist nur selten zugunsten des Kellers zu beantworten.

Was den Befund umkehren würde: ein Modell, das auf einem einzelnen Arbeitsplatzgerät mit vertretbarem Aufwand läuft und die Belegpflicht trägt. Das ist der Punkt, auf den die jährliche Durchsicht zu sehen hat.

3.3 Datenminimierung, die umgesetzt ist

Maßnahme	Nachweis
Kein Akteninhalt im Protokoll	technisch erzwungen an zwei Stellen: `security/protokoll.py` weist Inhaltsfelder zurück, `fehlergrenze.py` nimmt jedem Protokolleintrag den Traceback ab. Der zweite Riegel ist seit dem 05.10.2026 da; bis dahin galt der erste nur für den eigenen Protokollkanal (Befund F01 der Zweitprüfung)
Nachweis nur mit Prüfsumme und Länge	`domain/models.py::Nutzungseintrag`
Objektnamen ohne Aktenzeichen	nur SHA-256-Ableitung
Auswahl der Passagen durch den Bearbeiter	zwei Fenster, Haken je Dokument
Vorauswahl schließt Rechnungen und RSV aus	seit 05.10.2026, `JUSPERFECT_NICHT_VORWAEHLEN`
Der Korrespondenzordner wird nicht gelesen	seit 05.10.2026, seit dem 06.10.2026 ganz ausgebaut; an seiner Stelle der aktenbezogene Weg des Herstellers, noch nicht eingeschaltet. Siehe Risiko R1

---

4. Die Risiken — und was ihnen entgegensteht

Acht Risiken, in der Reihenfolge, in der sie die Entwicklung für erheblich hält.

[KANZLEI 5] — die Einstufung. Entwurf zur Übernahme, geschrieben am 15.10.2026. Bewertet ist das Risiko **nach** den beschriebenen Maßnahmen, aus Schwere für die Betroffenen und Wahrscheinlichkeit des Eintritts.

Risiko	Schwere	Wahrscheinlichkeit	Nach Maßnahmen
R1 Fremde Dokumente in einer Akte	hoch — Kernbereich des § 203 StGB	gering: der Weg ist ausgebaut, nicht nur abgeschaltet	**mittel**

Risiko	Schwere	Wahrscheinlichkeit	Nach Maßnahmen
R2 Eine falsche Aussage wird für wahr genommen	mittel bis hoch — sie könnte in einen Schriftsatz geraten	gering: Belegpflicht, Rückhalt bei fehlendem Beleg, anwaltliche Prüfung	**mittel**
R3 Die Arbeitskopie bleibt liegen	mittel	gering: seit 15.10.2026 fragt das Programm nach zwölf Monaten, ob die Akte noch läuft. Eine unbeantwortete Frage löscht aber nichts	**mittel**
R4 Übermittlung an den Auftragsverarbeiter	hoch — Berufsgeheimnis	gering: Vertrag, kein Training, keine Aufbewahrung beim eingesetzten Modell, Zero Operator Access	**mittel**
R5 Drittlandbezug	hoch, falls er bestünde	**nicht abschließend feststellbar**, solange die Auskunft zum Geländerprofil fehlt (`[KANZLEI 11]`)	**mittel**
R6 Besondere Kategorien, verstärkt durch die Texterkennung	hoch — Art. 9	gering: dieselben Maßnahmen wie R4, dazu die wirksame Abmelderichtlinie	**mittel**
R7 Zugriff innerhalb der Kanzlei	hoch — jede Akte für jeden	gering bis mittel: der offene Zugriff ist seit 15.10.2026 **entschieden** und getragen von Verschwiegenheitsverpflichtung, zweitem Faktor und Zuordnung jedes Zugriffs	**mittel**
R8 Auskunft, Berichtigung, Löschung	mittel	gering: gezielte Löschung einzelner Einträge seit 05.10.2026	**gering**

> **Kein Risiko steht mehr auf „hoch" — seit dem 15.10.2026.** Am Vormittag stand R7 dort: im Haus konnte jeder jede Akte öffnen, und die Anmeldung verlangte kein Kennwort. Beides ist beantwortet, aber auf verschiedene Weise. Der **zweite Faktor** beantwortet, *wer* zugreift. Dass jeder jede Akte sehen darf, ist eine **Entscheidung** der Kanzlei und kein Versäumnis (`[KANZLEI 13]`).
>
> **Die Einstufung hängt noch an zwei Stellen.** Mit der Auskunft zu `[KANZLEI 11]` fiele R5 auf „gering"; R3 ist mit der Rückfrage „Läuft die Akte noch?" vom 15.10.2026 bereits entschärft und bleibt nur deshalb auf „mittel", weil eine unbeantwortete Frage nichts löscht — die sichere Richtung, aber eben keine Frist.

Warum keines der acht auf „gering" steht außer R8. Weil in einer Mandatsakte die *Schwere* immer hoch ist, auch wenn die Wahrscheinlichkeit klein wird. Ein Verstoß gegen

das Berufsgeheimnis ist nicht teilbar. Die Maßnahmen wirken auf die Wahrscheinlichkeit, nicht auf die Schwere — und deshalb endet die Bewertung bei „mittel" und nicht tiefer.

Was die Entwicklung zu dieser Einstufung nicht sagen kann: wie die Kanzlei das Berufsgeheimnis im Verhältnis zur Bearbeitungsqualität gewichtet und welche Rechtsgebiete sie führt. Fällt diese Gewichtung anders aus, ist die Tabelle zu ändern.

R1 · Vermengung von Mandaten

Das größte Risiko, und es ist am 05.10.2026 eingetreten.

Akteninhalt eines fremden Mandats wurde in die Arbeitsakte eines anderen gelesen und ging an das Modell — in einer Akte 17 von 55 Dokumenten, an drei Akten dasselbe Muster.

Die Ursache liegt im Programm. Am Abend des 05.10.2026 hat die Beschreibung des Herstellers sie gezeigt: jur|nodes führt **zwei getrennte Ordnerbäume** mit je eigenen Nummern — das Dateisystem und die Korrespondenz. Das Programm hat die Nummer des **Korrespondenz**ordners an den Pfad des **Dateisystems** geschickt. Dort gibt es diese Nummer auch; sie gehört zu einem anderen Ordner, und zwar zu dem einer fremden Akte.

Die Fassung dieses Entwurfs von heute früh führte den Vorgang auf ein Verhalten der Schnittstelle zurück und hielt fest, das Programm habe richtig gearbeitet. **Das war falsch und ist hiermit berichtigt.**

Folge für die Betroffenen	**Dass Angaben aus ihrem Mandat in der Bearbeitung eines fremden Mandats auftauchen — der Kernbereich des § 203 StGB**
Was es verhindert hat	Das Aktengedächtnis war zu diesem Zeitpunkt **aus**. Es ist nichts dauerhaft abgelegt worden
Was seitdem gilt	Der falsche Weg wird nicht mehr gegangen. Die Korrespondenz fehlt damit — die sichere Richtung
Was das Programm selbst prüft	Der Durchlauf durch die Ordner meldet ausdrücklich, wenn er die Akte verlässt
Der richtige Weg	ist seit dem 05.10.2026 belegt (`POST /correspondence/search`) und in der Probe gemessen, aber **noch nicht im Betrieb**. Erst ein Lauf an einer echten Akte zeigt, was der Server liefert

~~[KANZLEI 6]~~ — von der Kanzlei entschieden. Die Kanzlei hat diesen Punkt als erledigt bezeichnet; er wird hier nicht erneut aufgeworfen. Für die Akte bleibt festgehalten, was ohnehin gilt: Der Vorgang ist in dieser Unterlage und in `MORGEN.md` nach Hergang, Ursache, Umfang und Abhilfe beschrieben, und damit ist er dokumentiert.

Aus Sicht der Entwicklung **kein Abfluss nach außen**: eigener Aktenbestand, eigenes AWS-Konto, derselbe Auftragsverarbeiter.

Für diese Bewertung erheblich: Die Ursache liegt im Programm und damit beim Verantwortlichen, nicht beim Auftragsverarbeiter und nicht beim Hersteller der

Aktenverwaltung. Umfang und Richtung des Vorgangs ändert das nicht, die Zurechnung schon.

R2 · Eine falsche Aussage wird für wahr genommen

Ein Sprachmodell erzeugt plausibel klingende Sätze. Übernimmt ein Bearbeiter einen davon ungeprüft in einen Schriftsatz, trifft der Schaden den Mandanten.

Was dagegen steht — und es ist die tragende Maßnahme des ganzen Programms:

Maßnahme	Wirkung	Nachweis
Belegpflicht, fail closed	Eine Aussage ohne Verweis auf eine mitgeschickte Passage wird **entfernt**, nicht markiert. Seit dem 05.10.2026 für **jeden** angezeigten Modelltext: Antwort, Entwurf, Kernaussage der Eingangsprüfung, Hinweise des Modells – und schon im laufenden Text, nicht erst am Ende (Befunde F04/F05 der Zweitprüfung)	`services/belegpflicht.py`
Fundstellen auf Passageneben e	`D2-S1-P3` — jede Aussage ist am Originaldokument nachprüfbar, mit einem Klick	
Die tragende Stelle wird hervorgehoben	und wenn sie sich nicht zuordnen lässt, steht das daneben: *„Bitte nachlesen."*	
Fristensperre	Fristen werden erkannt, nie berechnet — auch wenn die Akte dazu auffordert	`services/fristen.py`, in vier Prüfbogenläufen gehalten
Verweigerung statt Vermutung	*„kein belastbarer Beleg"* ist eine zulässige Antwort	

Was offen bleibt: Die Belegpflicht sichert, dass ein Satz **auf einer Stelle beruht**. Sie sichert nicht, dass die Stelle den Satz **trägt**. Das bleibt die Aufgabe des Bearbeiters — und ist der Grund, warum die Mitarbeiterschulung in Abschnitt 6 steht und nicht als Nebensache.

R3 · Die dauerhafte Fallkopie

Seit dem 05.10.2026 liegt Akteninhalt dauerhaft außerhalb von jur|nodes: ein zweiter Ort, der gesichert, verschlüsselt, mit einer Löschfrist versehen und bei einem Auskunftsverlangen mitbedacht werden muss.

Maßnahme	Stand
Eigener Bucket, eigenes Konto, Frankfurt	28.09.2026 eingerichtet
SSE-KMS, symmetrischer Single-Region-Schlüssel der Kanzlei	kein Schlüsselmaterial verlässt Frankfurt
Öffentlicher Zugriff vollständig blockiert, Versionierung aus	was gelöscht wird, soll gelöscht sein
Objektnamen ohne Aktenzeichen	nur SHA-256-Ableitung
Beschränkter Programmbenutzer	nur dieser Bucket, nur dieser Schlüssel
Gezielte Löschung einzelner Einträge	seit 05.10.2026: ein Dokument samt allem Abgeleiteten, oder eine einzelne Frage-Antwort-Runde. Bedient Art. 16 und 17 ohne Verwerfen der ganzen Fallkopie. Erfasst sind auch offene Sitzungen und verspätete Ergebnisse — ein Löschverlangen, das nur gilt, solange niemand ein zweites Fenster offen hat, wäre keines
Obergrenzen	100 Frage-Antwort-Runden, 500 Zeitstrahleinträge

[KANZLEI 7] — die offene Entscheidung: Wann wird gelöscht? Heute beginnt eine Löschfrist **nie von selbst**. Gelöscht wird nur, wenn ein Bearbeiter die Akte in jusperfect abschließt; danach läuft eine Übergangsfrist (Vorgabe 30 Tage), und erst dann wird gelöscht.

Das ist die sichere, aber unbefriedigende Seite: Es wird nichts gelöscht, was bleiben soll — aber es bleibt auch, was gehen könnte. Dass der Aktenstatus aus jur|nodes die Löschung auslösen kann, ist seit dem 28.09.2026 technisch belegt.

> **Eine Einschränkung, die dazugehört:** Das Programm erkennt im Feld `recordStatus` genau zwei Wörter als „abgeschlossen". Jedes andere gilt stillschweigend als „laufend" — die ungefährliche Richtung, aber eine Akte, die in jur|nodes anders abgeschlossen heißt, wird nie abschlussreif. Welche Wörter der Bestand wirklich führt, zeigt die Probe an.

[KANZLEI 7] — die Löschfrist. Entwurf zur Übernahme, geschrieben am 15.10.2026.

> **Zur Löschung der Arbeitskopie.** Die Arbeitskopie einer Akte wird gelöscht, wenn die Akte in jusperfect abgeschlossen wird und danach **30 Tage** verstrichen sind. Hat zwölf Monate lang keine Sitzung zu dieser Akte stattgefunden, fragt das Programm beim nächsten Öffnen, **ob die Akte noch läuft**. Wird das bejaht, verlängert sich die Frist um weitere zwölf Monate; die Antwort wird mit Datum und Bearbeiter vermerkt. Wird es verneint, beginnt die Übergangsfrist von 30 Tagen. Ohne Antwort wird nichts gelöscht. Die Akte selbst bleibt davon unberührt; sie unterliegt § 50 Abs. 1 BRAO.

Warum eine zweite Frist, und warum gerade diese. Heute beginnt eine Löschfrist **nie von selbst**: Wer eine Akte nicht abschließt, behält die Arbeitskopie für immer. Das ist die

sichere Richtung — und zugleich ein Verstoß gegen Art. 5 Abs. 1 lit. e, der keine Frist kennt, die vom Fleiß des Bearbeiters abhängt. Die zweite Frist knüpft deshalb an eine Tatsache, die nicht vergessen werden kann: dass nichts geschieht.

Zwölf Monate, nicht drei. Eine kürzere Frist träfe die liegengebliebene, aber lebende Akte — die, bei der ein Gutachten erwartet wird oder ein Verfahren ruht. Nach einem Jahr ohne jede Sitzung ist die Arbeitskopie kein Hilfsmittel mehr, sondern ein Vorrat.

> **Am 15.10.2026 gebaut — und auf Weisung der Kanzlei anders, als hier zuerst stand.** Der Entwurf von heute früh sah vor, nach zwölf Monaten ohne Sitzung zu **löschen**. Aus der Kanzlei dazu:
>
> „Du musst fragen: Läuft die Akte noch. Akten laufen manchmal jahrelang. Wenn die Frage mit Ja beantwortet wird, dann verlängert sich die Löschfrist um 12 Monate."
>
> **Das ist der bessere Entwurf, und der Grund ist nicht Vorsicht, sondern Richtigkeit.** Eine Akte, in der ein Gutachten erwartet wird oder ein Verfahren ruht, läuft weiter, auch wenn niemand sie öffnet. Sie zu löschen, weil die Zeit vergangen ist, nähme der Kanzlei die Arbeitskopie eines lebenden Mandats.
>
> **Deshalb löst die Zeit jetzt die FRAGE aus und nicht die Löschung.** Nach zwölf Monaten ohne Sitzung fragt das Programm beim Öffnen der Akte: *Läuft die Akte noch?* „Ja" verlängert um zwölf Monate und wird mit Datum und Bearbeiter vermerkt. „Nein" setzt die Übergangsfrist in Gang. Wer nicht antwortet, verliert nichts — die Frage bleibt und kommt wieder.
>
> `jusperfect/services/aufbewahrung.py`, 19 Prüfungen in `tests/test_laeuft_die_akte_noch.py`.
>
> **Und die Probe aus dem vorigen Kasten gehört dazu:** Solange nicht feststeht, welche Wörter der Bestand im Feld `recordStatus` führt, kann die erste Frist bei einem Teil der Akten nie anlaufen.

R4 · Übermittlung an einen Auftragsverarbeiter, der dem Berufsgeheimnis unterliegt

Akteninhalt geht an AWS. Das ist eine Übermittlung an einen Dritten im Sinne des § 203 Abs. 3 StGB und des § 43e BRAO.

Maßnahme	Stand
AV-Vertrag und Hauptvertrag	liegen vor: **AWS Data Processing Addendum**, **AWS-Kundenvereinbarung** (01.06.2026), **AWS-Datenschutzhinweis** (18.05.2026) — alle drei unten gelesen; `[KANZLEI 8]` nur noch für Ablage
Verpflichtung zur Verschwiegenheit in Textform (§ 43e Abs. 3 BRAO)	**[KANZLEI 9]** — Entwurf unten. **Die schwächste Stelle des Vertragswerks**
Dokumentation der Dienstleisterauswahl (§ 43e Abs. 2)	**Material beschafft am 14.10.2026** — sieben Nachweise aus AWS Artifact, Anlagen 7 bis 13; die Bewertung ist am 15.10.2026 geschrieben, siehe unten. `[KANZLEI 10]` nur noch für die Übernahme

Maßnahme	Stand
Kein Modelltraining	**Kundenvereinbarung Ziffer 1.4 und 6.1** (Fassung 01.06.2026) — nicht im AV-Vertrag, siehe unten
Ein einziger Ausgang im Programm	`services/ausgang.py` — genau eine Stelle führt zum Modell
Kein zweiter Anbieter	andere sind vorbereitet, keiner angebunden

[KANZLEI 9] — die Verschwiegenheitsverpflichtung nach § 43e BRAO. Entwurf zur Übernahme, geschrieben am 15.10.2026. Dies ist die Stelle, an der ich am wenigsten beruhigt bin.

Was das Berufsrecht verlangt. § 43e BRAO erlaubt dem Rechtsanwalt, sich eines Dienstleisters zu bedienen, knüpft das aber an einen Vertrag in **Textform**, in dem der Dienstleister **zur Verschwiegenheit verpflichtet** und **darüber belehrt** wird, dass er strafrechtlich wie ein Gehilfe des Rechtsanwalts behandelt wird (§ 203 Abs. 4 StGB).

Was der Vertrag mit AWS enthält. Eine Verschwiegenheitsregelung besteht; sie ist oben Abschnitt für Abschnitt gelesen. **Was er nicht enthält, ist die Belehrung** — eine auf § 203 StGB zugeschnittene Erklärung steht in keinem der drei Stücke, und AWS verhandelt seine Verträge nicht.

> **Das ist kein Mangel dieser Kanzlei, sondern der Lage.** Kein großer Cloud-Anbieter unterzeichnet eine Verpflichtungserklärung nach deutschem Berufsrecht. Wer diese Dienste nutzt, steht vor derselben Frage — nur beantworten die wenigsten sie schriftlich. Genau deshalb steht sie hier.

Der Weg, zu dem ich rate. Die Belehrung ist eine Pflicht **der Kanzlei**, nicht eine Leistung des Dienstleisters. Sie lässt sich einseitig erfüllen — **das Schreiben ist am 15.10.2026 aufgesetzt** und liegt in `BELEHRUNG-AWS.md` als Word und PDF bereit, zum Übernehmen auf den Briefbogen. Nach dem Absenden ist hier einzutragen:

> **Zur Verschwiegenheitsverpflichtung nach § 43e BRAO.** Die Kanzlei hat den Auftragsverarbeiter am TT.MM.JJJJ in Textform über die Verschwiegenheit nach § 43a Abs. 2 BRAO und über § 203 Abs. 4 StGB belehrt und ihn zur Verschwiegenheit verpflichtet. Eine gesonderte Gegenerklärung liegt nicht vor; der Auftragsverarbeitungsvertrag enthält eine Verschwiegenheitsregelung. Die Belehrung ist nebst Sendenachweis zur Datenschutzakte genommen.

Drei Dinge, die diesen Absatz tragen — und eines, das er nicht leistet.

1. **Die Belehrung ist zugangsbedürftig, nicht zustimmungsbedürftig.** Sie wirkt, wenn sie den Empfänger erreicht; ob er sie bestätigt, steht im Gesetz nicht.
2. **Der Sendenachweis ist der Beleg**, nicht die Antwort. Deshalb gehört er in die Akte.
3. **Die Datenminimierung trägt mit.** Je weniger hinausgeht, desto weniger hängt an dieser Stelle — und es geht nur hinaus, was angehakt ist.
4. **Was er nicht leistet:** Er macht aus einer bestrittenen Rechtslage keine sichere. Wer meint, § 43e verlange eine beidseitige Erklärung, wird das weiter meinen. **Diese Stelle bleibt das größte rechtliche Restrisiko des ganzen Vorhabens**, und sie gehört in die Bewertung nach `[KANZLEI 17]`.

> **Mein Rat, ausdrücklich:** Die Belehrung absenden, den Nachweis ablegen, und den Vorbehalt in Abschnitt 7 stehen lassen. Nicht: die Stelle für geklärt erklären, weil der Vertrag „eine Verschwiegenheitsregelung enthält". Das ist sie nicht.

Der Auftragsverarbeitungsvertrag, Abschnitt für Abschnitt

Gelesen am 14.10.2026 am vorgelegten Stück „AWS Data Processing Addendum" (englisch, zehn Seiten, Anlage 1 „Security Standards"). Die Abschnittsnummern unten sind die des Vertrages.

Was Art. 28 Abs. 3 DSGVO verlangt, und wo es steht:

Verlangt	Im Vertrag
Verarbeitung nur auf dokumentierte Weisung (lit. a)	Abschn. 2; Weisung sind der Vertrag und die Einstellungen in Konsole und Schnittstelle
Vertraulichkeit des eingesetzten Personals (lit. b)	Abschn. 4
Technische und organisatorische Maßnahmen (lit. c)	Abschn. 5 und Anlage 1
Unterauftragsverarbeiter (lit. d)	Abschn. 6 — **allgemeine** Genehmigung, 30 Tage Vorankündigung
Unterstützung bei Betroffenenrechten (lit. e)	Abschn. 7
Unterstützung bei Meldungen und Folgenabschätzung (lit. f)	Abschn. 9 und 10.4
Löschung oder Rückgabe am Ende (lit. g)	Abschn. 14 — bis 90 Tage nach Vertragsende
Nachweise und Überprüfungen (lit. h)	Abschn. 10 und 11
Drittlandübermittlung	Abschn. 12 — Standardvertragsklauseln, einbezogen durch Verweis

Vier Stellen, die in die Bewertung gehören und keine Formalien sind:

1. **Abschnitt 3 ist die Stelle, auf die es bei § 203 StGB ankommt.** AWS darf auf Kundendaten nicht zugreifen, sie nicht verwenden und sie nicht an Dritte geben — außer soweit zur Erbringung des Dienstes nötig oder aufgrund eines rechtswirksamen behördlichen Verlangens. Beim behördlichen Verlangen sagt AWS zu, die Behörde an die Kanzlei zu verweisen und die Kanzlei zu unterrichten, **soweit nicht rechtlich untersagt**. Dieser letzte Halbsatz ist das verbleibende Risiko und lässt sich vertraglich nicht wegnehmen.
2. **Beim Unterauftragsverarbeiter gibt es kein Vetorecht**, nur einen Ausgang: kündigen, den Dienst nicht mehr nutzen, oder in eine Region ausweichen, in der dieser Unterauftragsverarbeiter nicht eingesetzt ist (Abschn. 6.1). Wer widersprechen will, muss also gehen. Das ist bei Hyperscalern üblich und gehört trotzdem in die Abwägung.
3. **Die Prüfung erfolgt über Berichte, nicht vor Ort.** Die Kanzlei übt ihr Prüfrecht aus, indem sie AWS anweist, die Prüfung nach Abschn. 10 durchzuführen — ISO-

Zertifikate und SOC-Berichte gegen eine Vertraulichkeitsvereinbarung (Abschn. 11). Eine eigene Besichtigung des Rechenzentrums gibt es nicht.

4. **Abschnitt 12.1 trägt unsere Regionswahl.** AWS verbringt Kundendaten nicht aus der gewählten Region — *außer soweit zur Erbringung des Dienstes nötig*. Genau unter diesen Vorbehalt fallen das EU-Inferenzprofil und das Geländerprofil, die auf mehrere europäische Regionen verteilen (R5). Die Regionswahl `eu-central-1` des Programms ist damit vertraglich gedeckt, die Verteilung innerhalb Europas ebenfalls — eine Festlegung auf **ein** Rechenzentrum ist der Vertrag nicht.

[KANZLEI 21] — was in diesem Vertrag NICHT steht, und wo es stehen müsste. Das vorgelegte Stück enthält **kein Wort** zu Modelltraining oder zur Verwendung von Inhalten zur Verbesserung der Dienste. Der einzige Satz in diese Richtung ist Abschnitt 3 („nur soweit zur Erbringung des Dienstes nötig") — allgemein gehalten, und ausdrücklich nachrangig: **Abschnitt 16 bestimmt, dass die AWS Service Terms diesem Vertrag vorgehen.** Die Zusage zu Bedrock steht dort und nicht hier.

> **Daraus folgt für diese Unterlage:** Die Zeile „Kein Modelltraining — im AWS-Vertragswerk zugesichert" stand bis zum 14.10.2026 ohne Fundstelle da. Die Fundstelle ist noch am selben Tag beigebracht worden, aber sie steht **nicht hier**, sondern in der Kundenvereinbarung — siehe den nächsten Abschnitt. Wer nur den AV-Vertrag liest, findet sie nicht; deshalb bleibt dieser Hinweis stehen.

Die Nachweise der Prüfer

Am 14.10.2026 aus AWS Artifact abgerufen und in der Datenschutzakte abgelegt. Sie liegen bewusst nicht im Programmordner: Der SOC-2-Bericht ist vertrauliche Information von AWS, und der Ordner wird weitergegeben.

Nachweis	Was er sagt
ISO 27001:2022	Informationssicherheit, das Grundzertifikat
ISO 27017:2015	Sicherheit in der Cloud
ISO 27018:2019	Schutz personenbezogener Daten in der Cloud
ISO/IEC 27701:2019	Datenschutz-Managementsystem
SOC 2 Typ 2, Berichtszeitraum **01.04.2025 – 31.03.2026**	Prüfurteil über die **Wirksamkeit** der Kontrollen, nicht nur über ihr Vorhandensein — geprüfte Kriterien: Security, Availability, **Confidentiality**, **Privacy**
SOC 3	dasselbe Prüfurteil in einer Fassung, die weitergegeben werden darf
SOC Continued Operations Letter	schließt die Lücke zwischen dem Ende des Berichtszeitraums und heute

Wozu das trägt. § 43e Abs. 2 BRAO verlangt, dass die Auswahl des Dienstleisters dokumentiert ist — dass die Kanzlei ihn sich *angesehen* hat und nicht nur beauftragt. Das ist hiermit belegbar. Der Vertrag verspricht diese Unterlagen in seinem Abschnitt 10; Artifact ist der Weg dorthin.

Zwei Einschränkungen, die zum Nachweis gehören:

1. **Der SOC-2-Bericht darf nicht zitiert werden.** Die Vertraulichkeitsvereinbarung beim Abruf untersagt Auszüge. Deshalb steht aus ihm in dieser Unterlage nichts —

nur, dass er vorliegt, für welchen Zeitraum und mit welchen Kriterien. An eine **Aufsichtsbehörde** darf er vollständig gehen, mit dem Antrag auf vertrauliche Behandlung; jede Weitergabe ist zu notieren. An Mandanten geht **SOC 3**.

2. **Der Berichtszeitraum endete am 31.03.2026.** Für die Zeit danach trägt der Bericht nichts. Die Lücke schließt das **SOC Continued Operations Letter** aus derselben Quelle. Zur jährlichen Durchsicht dieser Unterlage gehört, die Nachweise neu abzurufen.

[KANZLEI 10] — die Bewertung. Entwurf zur Übernahme, geschrieben am 15.10.2026.

Bis dahin stand hier „das Material liegt vor; der Satz dazu fehlt". Der Satz ist jetzt geschrieben; zu entscheiden bleibt, ob er so übernommen wird.

> **Zur Auswahl des Auftragsverarbeiters nach § 43e Abs. 2 BRAO.** Die Kanzlei hat Amazon Web Services EMEA SARL vor der Beauftragung geprüft. Geprüft wurden das Vertragswerk (Auftragsverarbeitungsvertrag, Kundenvereinbarung, Datenschutzhinweis, Service Terms Abschnitt 50.12), die technische Ausgestaltung des Kontos (Zugriffsrichtlinie auf sechs EU-Regionen, Opt-out-Richtlinie für die KI-Dienste, Modellwahl) und die Nachweise unabhängiger Prüfer. Die Prüfung ist im Aktenvermerk vom 14.10.2026 nebst 17 Anlagen dokumentiert. Die Kanzlei hält den Auftragsverarbeiter für die vorgesehene Verarbeitung für geeignet.

Was die Nachweise tragen — und was nicht. Das gehört zur Bewertung, weil ein Zertifikat mehr zu versprechen scheint, als es sagt.

ISO 27001:2022	Es besteht ein geprüftes Managementsystem für Informationssicherheit. Das sagt, dass es *Verfahren gibt* — nicht, dass sie im Einzelfall gewirkt haben
ISO 27017 / 27018	Dieselbe Art Aussage, zugeschnitten auf Cloud-Dienste und auf personenbezogene Daten darin
ISO/IEC 27701:2019	Ein Datenschutz-Managementsystem besteht und ist geprüft
SOC 2 Typ 2	**Das tragende Stück.** Typ 2 heißt: Ein unabhängiger Prüfer hat über einen Zeitraum hinweg beurteilt, ob die Kontrollen *wirksam waren* — nicht nur, ob sie eingerichtet sind. Geprüft wurden unter anderem die Kriterien **Confidentiality** und **Privacy**, und das sind die beiden, auf die es bei einer Mandatsakte ankommt
SOC 3	Dasselbe Urteil in einer Fassung, die weitergegeben werden darf
Continued Operations Letter	Schließt die Lücke zwischen dem Ende des Berichtszeitraums und heute

Drei Grenzen, die zu nennen sind, weil sie sonst übersehen werden:

1. **Die Nachweise gelten dem Anbieter, nicht diesem Konto.** Geprüft ist AWS als Dienst. Ob die Kanzlei ihr Konto richtig eingerichtet hat — Regionen, Richtlinien, Modellwahl —, sagt kein Zertifikat. Das ist der Grund, warum die Handgriffe 1 bis 3 und ihre Anlagen zur selben Dokumentation gehören: **Die Zertifikate tragen den Anbieter, die eigenen Ausdrucke tragen die Einrichtung.**
2. **Der Berichtszeitraum endete am 31.03.2026.** Das Überbrückungsschreiben trägt die Zeit danach; beides läuft ab und gehört in die jährliche Durchsicht.

3. **Ein Zertifikat ersetzt die Verschwiegenheitsverpflichtung nicht.** § 43e Abs. 3 BRAO steht daneben und ist weiter offen (`[KANZLEI 9]`).

> **Die Einschätzung, auf die es ankommt — und sie fällt anders aus, als man erwartet.** Der eigentliche Nachweis nach § 43e Abs. 2 ist **nicht** der Stapel fremder Zertifikate. Den könnte jeder herunterladen, der ein AWS-Konto hat. Der Nachweis ist der **Aktenvermerk**: dass die Kanzlei das Vertragswerk gelesen, die Missbrauchserkennungsseite geprüft, die Modellwahl als Rechtsfrage behandelt und die Einrichtung des Kontos belegt hat. Die Zertifikate untermauern das; sie sind nicht selbst die Auswahl. **Die Norm verlangt eine Entscheidung, und eine Entscheidung besteht nicht aus fremden Urkunden.**

Was darüber hinaus in die Akte soll — die zweite Hälfte der Frage:

- Der **Aktenvermerk vom 14.10.2026** mit allen Anlagen. Er *ist* die Dokumentation; alles Übrige ist Beleg dazu.
- Die **unterschriebene Einweisung** — sie zeigt, dass die Auswahl nicht nur getroffen, sondern im Haus durchgesetzt wird.
- Jede **Weitergabe des SOC-2-Berichts**, mit Datum und Empfänger.
- Bei einem **Modellwechsel** der ausgefüllte Prüfbogen (`AWS-ZWEI-HANDGRIFFE.md`, Handgriff 4): Die Auswahl hängt am Modell, und eine Auswahl, die sich ändert, ist erneut zu dokumentieren.

Vollständig seit dem 15.10.2026. Die beiden Stücke, die der Aktenvermerk bei den Anlagen 14 und 17 noch als nachzureichen bezeichnet — der vollständige Ausdruck der Vertraulichkeitsbedingungen und ein Ausdruck der Seite „Amazon Bedrock abuse detection" —, liegen vor. Die Kanzlei hat das am 15.10.2026 bestätigt. **Aus der AWS-Konsole ist für diese Unterlage nichts mehr zu holen**; die nächste Vorlage ist die jährliche Durchsicht.

Die Kundenvereinbarung und der Datenschutzhinweis

Am 14.10.2026 nachgereicht und gelesen: die AWS-Kundenvereinbarung (deutsche Fassung, Stand 01.06.2026) und der AWS-Datenschutzhinweis (Stand 18.05.2026). Beide frisch von AWS abgerufen.

Hier steht, was im AV-Vertrag fehlte. Ziffer 1.4 der Kundenvereinbarung ist die tragende Stelle, und sie ist weiter als Abschnitt 3 des AV-Vertrages: Sie gilt für **„Ihre Inhalte"** und nicht nur für personenbezogene Daten.

> „Wir werden nicht auf Ihre Inhalte zugreifen oder diese nutzen, es sei denn, dass dies notwendig ist, um die Services zu warten oder anzubieten oder erforderlich, um die Gesetze einzuhalten oder einer verbindlichen Anordnung einer staatlichen Stelle nachzukommen."

Dazu Ziffer 6.1: AWS erhält keine Rechte an den Inhalten; die Kanzlei stimmt ihrer Nutzung nur zu, „um Ihnen und allen Endnutzern die Services zur Verfügung zu stellen". Ein Modell mit Akteninhalt zu trainieren ist keines von beidem. **Damit hat die Zeile „kein Modelltraining" eine Fundstelle** — sie steht in der Kundenvereinbarung und nicht im AV-Vertrag, und sie ist eine allgemeine Nutzungsschranke und keine Zusage zu einem bestimmten Dienst.

Drei weitere Sätze derselben Ziffer, die hierhergehören:

1. AWS gibt Inhalte **nicht an staatliche Stellen oder Dritte** weiter und verlagert sie nicht aus den gewählten Regionen — außer soweit im Einzelfall gesetzlich oder

durch verbindliche Anordnung gefordert. Über eine solche Anordnung wird die Kanzlei unterrichtet, **„es sei denn, dass dies uns gesetzlich oder durch die Anordnung einer staatlichen Stelle untersagt ist"**. Das ist dasselbe verbleibende Risiko wie im AV-Vertrag, nur in anderen Worten; es ist nicht wegzuverhandeln und steht hier als bekannt.

2. **„Die Datenschutzerklärung ist auf Ihre Inhalte nicht anwendbar."** Das ist ein Satz, der eine Fehllesung verhindert: Wer den Datenschutzhinweis allein liest, findet dort als Zweck „die AWS-Angebote zu verbessern und zu entwickeln" und schließt daraus auf die Akte. Falsch — der Datenschutzhinweis sagt es selbst, gleich auf seiner ersten Seite: Er „gilt nicht für ‚Inhalte', die von unseren Kunden unter Nutzung von AWS-Angeboten in Verbindung mit einem AWS-Account verarbeitet, gespeichert oder gehostet werden." Er betrifft die **Account-Informationen** — Anschrift, Abrechnung, Nutzungsmessung —, nicht den Akteninhalt.
3. **Vertragspartei ist für Kunden mit Sitz in der EU die Amazon Web Services EMEA SARL in Luxemburg** (Ziffer 12 (e)). Für sie gilt zusätzlich, dass Haftung für grobe Fahrlässigkeit und Vorsatz nicht beschränkt ist.

> **Eine Falle in Ziffer 6.5, die den Umgang mit AWS betrifft und nicht die Technik.** Wer AWS einen **Vorschlag** macht — eine Anregung, eine Fehlermeldung mit Beispiel, einen Verbesserungswunsch —, überträgt AWS daran unwiderruflich sämtliche Rechte, „ohne jegliche Beschränkung". Daraus folgt eine Hausregel: **In eine Support-Anfrage oder einen Verbesserungswunsch an AWS gehört niemals Akteninhalt**, auch kein anonymisierter Ausschnitt und kein Bildschirmfoto mit Text. Der Support-Text in `AWS-ZWEI-HANDGRIFFE.md` ist danach gebaut.
>
> **Und ein Vorbehalt, der für beide Stücke gilt:** Sie liegen in deutscher Übersetzung vor, und beide tragen oben den Satz, dass die Übersetzung nur der Information dient und bei Abweichungen **die englische Fassung maßgeblich** ist. Für die Datenschutzakte gehört deshalb zu jedem deutschen Ausdruck der englische dazu.

[KANZLEI 21] — am 14.10.2026 beantwortet. Die Service Terms lagen nicht vor; sie gehen dem AV-Vertrag (Abschnitt 16) und der Kundenvereinbarung (Ziffer 11.2) **beiden vor**, und solange niemand sie gelesen hatte, stand die Schranke aus Ziffer 1.4 unter Vorbehalt. Der Abschnitt liegt jetzt vor — siehe den nächsten Abschnitt. Der Vorbehalt ist ausgeräumt; **dafür ist eine neue Stelle entstanden** (`[KANZLEI 22]`).

Die Service Terms, Abschnitt 50.12 — Amazon Bedrock

AWS Service Terms, Stand 15.09.2026, deutsche Fassung. Am 14.10.2026 gelesen. Auch hier gilt: Bei Abweichungen ist die englische Fassung maßgeblich.

Das Wichtigste zuerst: Eine Erlaubnis, Inhalte zum Training oder zur Verbesserung der Dienste zu verwenden, enthält der Abschnitt nicht. Die Schranke aus Ziffer 1.4 der Kundenvereinbarung bleibt damit unangetastet; die Aussage „kein Modelltraining" trägt.

Dass dieses Schweigen Absicht ist und keine Lücke, zeigt der unmittelbar folgende Abschnitt. In 50.13 (*Amazon Q*) schreibt AWS das Gegenteil ausdrücklich hin: Inhalte dürfen genutzt werden, „um Amazon Q und die zugrunde liegenden Technologien zu entwickeln und zu verbessern", einschließlich des „Trainieren[s] von Machine-Learning-Modellen", und dürfen dafür in einer anderen AWS-Region gespeichert werden; 50.13.3 verweist für den Widerspruch auf die **Opt-out-Richtlinie für KI-Services**. Wo AWS solche Rechte will, nennt es sie — und für Bedrock nennt es sie nicht. Das bestätigt zugleich den

Befund vom Vormittag, dass die Abmelderichtlinie (`[KANZLEI 19]`) für Bedrock kein Werkzeug ist: Sie hat dort nichts, woran sie greifen könnte.

Was der Abschnitt sonst regelt, geordnet nach Bedeutung für diese Akte:

Stelle	Inhalt
50.12.2 Erkennung von Missbrauch	**Für bestimmte Modelle** — genannt auf der Bedrock-Missbrauchserkennungsseite — speichert Bedrock **Ein- und Ausgaben bis zu 30 Tage**, zum alleinigen Zweck, Verstöße gegen die Nutzungsbedingungen zu erkennen. Bei erkanntem Verdacht **überprüft AWS** die Ein- und Ausgaben; der Kunde „stimmt zu und weist an". Siehe `[KANZLEI 22]`
50.12.2.1	Bei Verdacht auf Darstellungen von Kindesmissbrauch Prüfung und Meldung an das NCMEC oder eine andere Stelle
50.12.4	Ein durch Feinabstimmung angepasstes Modell steht allein der Kanzlei zu; Drittanbieter haben keinen Zugriff. AWS greift darauf nur zu, soweit zur Wartung oder Bereitstellung nötig oder gesetzlich gefordert. **Betrifft uns heute nicht** — jusperfect stimmt kein Modell ab
50.12.5	AWS darf dem Anbieter eines Drittanbieter-Modells Angaben zur Nutzung weitergeben, **die die Inhalte nicht umfassen**
50.12.5.1	Bestimmte Anthropic-Produkte (genannt werden Claude Code und die Computernutzung) betten **Metadaten** in Anfragen ein. **Betrifft uns nicht** — jusperfect ruft die Schnittstelle unmittelbar auf
50.12.1	Modelle von Drittanbietern sind „Inhalte von Drittanbietern"; ihre Nutzung heißt Zustimmung zu deren eigenen Bedingungen, über AWS Marketplace (Abschnitt 20)
50.12.6	Ausgaben können Herkunftsdaten tragen (Metadaten, Signaturen, Wasserzeichen); sie dürfen nicht entfernt werden

> **Eine Folgerung für den Betrieb, die nicht datenschutzrechtlich aussieht und es doch ist:** Nach 50.12.1 hängt die Rechtslage **am gewählten Modell**. Ein Wechsel auf ein Modell eines Drittanbieters aus dem Marktplatz unterstellt die Verarbeitung dessen Bedingungen — nicht mehr allein denen, die hier geprüft sind. Die Modellwahl ist deshalb keine rein technische Einstellung. `JUSPERFECT_MODELL` zu ändern ist eine Entscheidung mit Rechtsfolgen.

[KANZLEI 22] — die Missbrauchserkennung nach 50.12.2. Die beiden offenen Fragen dazu sind am 14.10.2026 beantwortet worden; siehe den nächsten Abschnitt. Übrig bleibt eine Bestätigung und eine Hausregel.

Die Missbrauchserkennungsseite und Abschnitt 1.24

Amazon Bedrock User Guide, Abschnitt „Abuse detection", und AWS Service Terms Abschnitt 1.24; beide am 14.10.2026 gelesen. Der User Guide ist Dokumentation und kein Vertrag — AWS kann ihn ohne Ankündigung ändern. Gerade deshalb gehört er mit Abrufdatum in die Akte.

Erstens: Abschnitt 1.24 betrifft die Kanzlei nicht. Er regelt *andere* AWS-Dienste, die eine von Bedrock betriebene KI-Funktion eingebaut haben — genannt werden unter anderem CloudWatch, CodeCatalyst, Connect, Q, SageMaker, WorkSpaces, Kiro, GuardDuty. jusperfect ruft die Bedrock-Schnittstelle **unmittelbar** auf und nutzt keinen dieser Dienste. Die Frage ist damit erledigt.

Zweitens, und das ist der Befund dieses Tages: Die Seite nennt die Modelle namentlich, für die gespeichert wird.

Modell	**Was gespeichert wird**
OpenAI-Modelle (bis auf vier genannte)	vom Klassifikator aufgefallener Verkehr, bis zu 30 Tage
Anthropic Claude Fable 5 und Claude Fable 5.1	**der gesamte Verkehr**, bis zu 30 Tage; aufgefallener Verkehr zusätzlich mit **möglicher menschlicher Überprüfung durch AWS**
alle übrigen	nichts — es gilt das **Zero-Operator-Access-Modell** (ZOA)

Das voreingestellte Modell von jusperfect ist `anthropic.claude-opus-4-6-v1` (`jusperfect/config.py:299`), als EU-Inferenzprofil `eu.anthropic.claude-opus-4-6-v1`. **Es steht nicht auf der Liste.** Für die Kanzlei gilt damit nach heutigem Stand der Seite: **keine Aufbewahrung, kein Mitlesen** — es greift das Zero-Operator-Access-Modell.

> **Zwei Vorbehalte, ohne die dieser Satz zu viel sagt.**
>
> 1. Maßgeblich ist das Modell, das in `START-JURNODES.bat` wirklich eingetragen ist (`JUSPERFECT_MODELL_ID`), nicht die Voreinstellung. **Die Kanzlei hat es am 14.10.2026 bestätigt:** `claude-opus-4-6-v1`. Dieser Punkt ist geschlossen. 2. **Die Liste ist Dokumentation und ändert sich.** Ein Modell kann hinzukommen, auch das heute genutzte. Sie gehört deshalb in die jährliche Durchsicht dieser Unterlage.

Daraus folgt eine Hausregel, die in die Einweisung gehört: Für Mandatsakten wird **kein Modell verwendet, das auf dieser Seite steht** — und vor jedem Modellwechsel wird sie angesehen. Ein Wechsel auf Claude Fable 5 oder 5.1 hieße nach heutigem Stand: *aller* Verkehr dreißig Tage bei AWS, aufgefallener mit menschlicher Durchsicht. Das ist keine Einstellung, die man nebenbei ändert (dazu schon oben zu 50.12.1).

Drei weitere Angaben der Seite, die hierhergehören:

1. **Regionsübergreifende Inferenz:** Würde ein gelistetes Modell genutzt, lägen die aufbewahrten Ein- und Ausgaben „in den Zielregionen" — also dort, wo die Anfrage verarbeitet wurde. Das `eu.`-Profil verteilt auf mehrere europäische Regionen (R5). Für das heute genutzte Modell ist das gegenstandslos, weil nichts aufbewahrt wird.
2. **CSAM-Erkennung:** Sie arbeitet auf **Bild**-Ein- und -Ausgaben. jusperfect sendet an Bedrock ausschließlich Text; gescannte Seiten gehen an Textract und nicht an Bedrock. Sie greift hier also nicht.
3. **Aufbewahrtes wird nicht an die Modellanbieter weitergegeben**, sondern allein von AWS gespeichert und verarbeitet.

> **Eine Pflicht, die nicht nach Datenschutz aussieht und den Betrieb trifft:** Erkennt AWS einen möglichen Verstoß, fragt es per E-Mail an die **Kontoadresse** nach — und

> kann den Zugang sperren, wenn niemand antwortet. Diese Adresse muss also gepflegt und gelesen werden. Eine unbeantwortete Rückfrage könnte jusperfect zum Stillstand bringen.

[KANZLEI 22] — Stand am Abend des 14.10.2026. Die beiden Hausregeln stehen in `EINWEISUNG.md` und warten dort nur noch auf die Kenntnisnahme.

Die Frage nach Art. 13 ist entschieden: Eine Aufbewahrung bei Bedrock wird in den Hinweisen nicht genannt — weil sie nicht stattfindet. Art. 13 Abs. 2 lit. a verlangt die Dauer der *tatsächlichen* Verarbeitung; eine Frist zu nennen, die nicht läuft, wäre unrichtig und würde Mandanten beunruhigen.

Statt dessen sind in `DATENSCHUTZHINWEISE-ENTWURF.md` drei Dinge geändert worden:

1. Die Speicherdauer sagt jetzt ausdrücklich, dass beim Auftragsverarbeiter **nichts darüber hinaus aufbewahrt** wird — eine Angabe, die vorher fehlte und die Art. 13 verlangt.
2. Die Zusage „kein Training" hat ihre Fundstelle bekommen (Ziffer 1.4 und 6.1 der Kundenvereinbarung, bestätigt durch Service Terms 50.12).
3. Der Satz im Hinweiskasten, der Auftragsverarbeiter sichere zu, Eingaben „weder zu speichern noch zum Training zu verwenden", ist **berichtigt**. Es gibt keine vertragliche Zusage der Nicht-Speicherung; sie folgt aus der Modellwahl.

> **Und daraus eine Abhängigkeit, die festzuhalten ist:** Die Hinweise nach Art. 13 sind nur so lange richtig, wie **Regel 1 der Einweisung** eingehalten wird. Wird ein gelistetes Modell eingesetzt, sind sie zu ändern. Das steht als Anmerkung für die Kanzlei an beiden Stellen der Hinweise — eine Rechtsunterlage, die von einer Betriebsregel abhängt, muss das sagen. Nach heutigem Stand ist dort **nichts über eine Aufbewahrung bei

Bedrock zu sagen** — das kann sich mit der Liste ändern, und deshalb gehört sie in die jährliche Durchsicht.

> **Was das für Abschnitt 2.1 und für `[KANZLEI 20]` heißt.** Die Mengenbegrenzung bleibt die wirksamste Maßnahme in der Hand des Bearbeiters und wird durch diesen Befund **wichtiger**, nicht unwichtiger: Was nicht angehakt ist, kann auch nicht dreißig Tage liegen. Die Entscheidung vom 14.10.2026 steht; sie behauptet an keiner Stelle, es werde nichts aufbewahrt. Ihr dritter „nicht behauptet"-Satz — die Speicherfrage sei geklärt — ist durch diesen Befund bestätigt und nicht widerlegt.

[KANZLEI 8] — was zur Ablage noch fehlt. Der Weg dorthin steht in `AWS-ZWEI-HANDGRIFFE.md`, Handgriff 3: In **AWS Artifact** liegen die Zertifikate und Prüfberichte bereit, die der Vertrag in seinem Abschnitt 10 verspricht, und dort steht auch, ob das Data Processing Addendum für dieses Konto **angenommen** ist — ein Nachweis, den das vorgelegte PDF nicht erbringt. Das Stück trägt keine Fassungsnummer, und der Vertrag gilt „in der jeweils geänderten Fassung" (Einleitungssatz). Für die Akte sind deshalb **drei** Dinge festzuhalten: der Tag des Abrufs, von welcher AWS-Seite abgerufen wurde, und ein Ausdruck des Stücks. Dazu gehören drei Unterlagen, auf die der Vertrag nur verweist und die er nicht enthält: die **Standardvertragsklauseln** (Abschn. 17, zwei verlinkte Stücke), die **Liste der Unterauftragsverarbeiter** (Abschn. 6.1) und die **AWS Service Terms** (Abschn. 16).

[KANZLEI 8] — die Ablage. Entwurf zur Übernahme, geschrieben am 15.10.2026.

Von den dreien liegen die **Service Terms** seit dem 15.10.2026 als Ausdruck bei (Anlage 15). Offen sind zwei, und beide sind Webseiten, keine Verträge:

Noch zu holen	Wo	Was festzuhalten ist
Standardvertragsklauseln	die beiden in Abschnitt 17 des AV-Vertrages verlinkten Stücke	Tag des Abrufs, Adresse, Ausdruck
Liste der Unterauftragsverarbeiter	die in Abschnitt 6.1 genannte Seite	dasselbe, und sie ist **zu beobachten**: Der Vertrag sieht eine Unterrichtung über neue Unterauftragsverarbeiter vor, und ein Widerspruchsrecht nützt nur, wer die Liste kennt

> **Zur Ablage des Vertragswerks.** Zur Datenschutzakte genommen sind der Auftragsverarbeitungsvertrag, die AWS-Kundenvereinbarung (Fassung 01.06.2026), der AWS-Datenschutzhinweis (Fassung 18.05.2026) und die AWS Service Terms (Stand 15.09.2026), jeweils mit dem Tag des Abrufs und der Fundstelle. Die Standardvertragsklauseln und die Liste der Unterauftragsverarbeiter sind am TT.MM.JJJJ abgerufen und beigefügt.

Warum der Tag des Abrufs zu jedem Stück gehört. Der Vertrag gilt „in der jeweils geänderten Fassung", und keines der Stücke trägt eine Fassungsnummer. Ohne das Abrufdatum lässt sich später nicht sagen, **welchem Text** die Kanzlei zugestimmt hat — und das ist die einzige Frage, die im Streitfall zählt.

Die Nutzungsrichtlinie des Modellanbieters

Aufgenommen am 15.10.2026, nachdem die Kanzlei die „Usage Policy" von Anthropic vorgelegt hat.

Die Kette, über die sie uns bindet, ist kurz. Nach **Service Terms 50.12.1** sind Modelle von Drittanbietern „Inhalte von Drittanbietern", und ihre Nutzung heißt Zustimmung zu **deren eigenen Bedingungen**. Die Nutzungsrichtlinie ist eine solche eigene Bedingung. Sie sagt es auf ihrer ersten Seite selbst: Sie gilt für „developers and businesses using our API and developer platforms, **customers accessing Claude through cloud providers and authorized resellers**". Der Weg über Bedrock ist genau dieser Fall.

> **Was die vorgelegte Fassung ist und was nicht.** Sie trägt oben einen gelben Hinweis, sie sei „for reference purposes only and may not be the current version", und ihr Datum lautet **„Effective Date: November 12, 2026"** — sie tritt also erst **nach** dem heutigen Tag in Kraft. Welche Fassung heute gilt, ist **nicht geprüft**; die geltende steht unter `anthropic.com/legal/aup`. Die Bewertung unten gilt für die vorgelegte Fassung und ist am 12.11.2026 gegen die dann geltende zu halten (`MORGEN.md`).

„Legal" ist der erste von elf Hochrisikobereichen. Die Richtlinie führt unter „High-risk AI Recommendations" auf:

> **Legal** — advising an individual on their legal rights, obligations, or liability, or on what to do in a specific legal matter, **or preparing legal documents for them to sign or file**.

Der letzte Halbsatz beschreibt die Entwurfsfunktion von jusperfect. Daran hängen zwei Anforderungen — und **beide sind erfüllt**, die zweite ohne dass die Kanzlei die Richtlinie kannte.

Anforderung	Wortlaut, verkürzt	Erfüllt durch
Qualified human-in-the-loop	Eine qualifizierte Person — „who holds a license where applicable law requires one" — muss die Ausgabe inhaltlich prüfen, sie ändern können und bleibt verantwortlich	Die Belegpflicht (Abschnitt 5); der Satz „Die anwaltliche Prüfung und jede Entscheidung bleiben bei der Kanzlei" in Fassung 1 der Mandatsklausel; `EINWEISUNG.md`
Disclosure for advice and decisions	Wer eine Beratung erhält, muss **klar gesagt bekommen, dass KI eingesetzt wurde**. „Users do not need to identify Anthropic, Claude, or the model used"	Teil A der Hinweise nach Art. 13; deutlicher der erste Satz der Klausel in Fassung 1 — in dem Dokument, das die Mandantschaft unterschreibt

> **Der Nachsatz zur Offenlegung ist für eine Kanzlei wichtiger, als er aussieht.** Die Richtlinie verlangt **nicht**, Anthropic, Claude oder das Modell zu benennen. Die Klausel spricht von „einem Auftragsverarbeiter in Rechenzentren innerhalb der Europäischen Union" und genügt damit — ohne dass die Kanzlei gegenüber der Mandantschaft mehr offenlegt, als sie muss.

Eine Ausnahme, auf die hier bewusst nicht gebaut wird — Einschätzung. Die Richtlinie nimmt aus: „Internal drafting, research, summarization, or analysis that is **not the ultimate High-risk AI Recommendation delivered**." Man kann vertreten, jusperfect falle darunter: Es antwortet dem Bearbeiter, nicht der Mandantschaft, und was hinausgeht, schreibt und verantwortet die Kanzlei. Dagegen steht, dass „preparing legal documents for them to sign or file" ausdrücklich **im** Hochrisikobereich aufgeführt ist, und ein geprüfter Entwurf, der hinausgeht, ist geliefert.

Die Frage muss nicht entschieden werden, und sie wird hier nicht entschieden. Die Kanzlei erfüllt beide Anforderungen ohnehin — durch die anwaltliche Prüfung und durch die Offenlegung in der Mandatsklausel. Damit kommt es auf die Ausnahme nicht an. Das ist der ruhigere Weg: Wer sich auf eine Ausnahme stützt, muss sie bei jeder Änderung der Richtlinie neu prüfen; wer die Anforderungen erfüllt, nicht. **Aus demselben Grund steht hier keine offene Stelle für die Kanzlei:** Es ist nichts zu entscheiden, solange Fassung 1 gewählt und die anwaltliche Prüfung eingehalten wird.

Drei weitere Stellen, kurz, damit nicht danach gesucht wird.

1. **Ein Verbot, kein Hochrisikobereich:** „Make or suggest decisions in law enforcement or criminal justice processes, including decisions to investigate, charge, arrest or detain, prosecute, sentence". Das sind **staatliche** Entscheidungen. Strafverteidigung ist das Gegenteil davon und nicht erfasst. Der Punkt steht hier, weil er beim ersten Lesen erschrickt und weil der Selbsttest ausdrücklich eine Körperverletzungssache durch das Schutzgeländer schickt.
2. **Verbraucher-Chatbots:** „All consumer-facing chatbots or AI agents that communicate directly with external users must disclose...". **Gilt nicht.** jusperfect spricht nur mit dem Bearbeiter; es gibt keine externen Nutzer. Die Stelle steht hier, weil sie auf den ersten Blick einschlägig aussieht.
3. **Privatsphäre:** „Misuse, collect, solicit, or gain access **without permission** to private information such as ... health data ... or confidential or proprietary data." Eine rechtmäßig geführte Mandatsakte, verarbeitet auf Art. 6 Abs. 1 lit. b und lit. f und Art. 9 Abs. 2 lit. f, ist weder „misuse" noch Zugriff „without permission".

> **Die Durchsetzung läuft über dasselbe Postfach wie alles andere.** Die Richtlinie behält sich vor, bei Verdacht zu „warn you or throttle, limit, suspend, or terminate your access". Über Bedrock geschieht das durch AWS — und AWS fragt dafür an der Kontoadresse nach. Das ist **Regel 2 der Einweisung**, und sie bekommt damit einen zweiten Grund.

Für die Akte: Das PDF der vorgelegten Fassung gehört in die Datenschutzakte, mit dem Tag der Vorlage. Es ist kein Vertrag im Sinne von Abschnitt 10 des Auftragsverarbeitungsvertrags und gehört nicht zu den Artifact-Nachweisen; es ist die Bedingung des Modellanbieters, auf die 50.12.1 verweist.

R5 · Drittlandbezug durch das EU-Inferenzprofil und das Schutzgeländer

Der `eu.`-Vorsatz hält die Verarbeitung in europäischen Regionen, verteilt sie aber auf mehrere. Dasselbe gilt für das Geländerprofil `eu.guardrail.v1:0`.

Grenze	Wirkung
Region in den Einstellungen	nur die **namentlich aufgeführten** EU- und EWR-Regionen zulässig; alles andere bricht beim Start ab Seit dem 05.10.2026 gilt dasselbe für die **Modellkennung**: Ein Inferenzprofil mit dem Vorsatz `global.` oder `us.` verteilt außerhalb der EU, gleich aus welcher Region es aufgerufen wird, und wird abgewiesen (Befund F13 der Zweitprüfung).
Zugriffsrichtlinie	ausdrückliches **Verbot** jedes Bedrock-Aufrufs außerhalb `eu-*` — ein Verbot wiegt in AWS schwerer als jede Erlaubnis
Durch das Geländer geht	nur Frage und Antwort, nicht der Akteninhalt

Am 05.10.2026 berichtigt, auf einen Hinweis aus der Kanzlei hin. Bis dahin prüften Programm und Richtlinie auf den Vorsatz `eu-`. Der ist eine Namenskonvention von AWS und **kein Nachweis**: `eu-central-2` ist Zürich (Schweiz), `eu-west-2` ist London (Vereinigtes Königreich). Beide hätten die Prüfung bestanden. Das Programm prüft seitdem gegen eine aufgeschriebene Liste; die Richtlinie noch nicht (geschützte Datei, Vorschlag in `DSFA-ANGABEN.md`).

Was auch die engere Liste nicht leistet: `aws:RequestedRegion` und die Einstellung betreffen die Region, an die der **Aufruf** geht — Frankfurt. Wohin das Inferenzprofil und das Geländerprofil intern verteilen, entscheidet AWS und steht in keiner Richtlinie. Deshalb bleibt die Auskunft von AWS erforderlich; und eine Antwort, die nur `eu-`-Regionen nennt, genügt dafür nicht.

[KANZLEI 11] — eine Angabe ist ungesichert. Welche Regionen das Geländerprofil benutzt, nennt AWS in der Konsole nicht. Eine Zusammenfassung aus zweiter Hand nennt Irland, Frankfurt, Paris, Mailand, Spanien, Stockholm — **und Zürich, also die Schweiz**. Für den Drittlandbezug wäre das erheblich, und genau deshalb darf es nicht aus zweiter Hand übernommen werden. **Beim AWS-Support zu erfragen**, ausdrücklich für das Geländerprofil und für die drei benutzten Modellkennungen.

[KANZLEI 11] — der Text für die Anfrage. Geschrieben am 15.10.2026. Abzusenden über den AWS-Support, Fall vom Typ „Account and billing" oder „Technical", Dienst „Amazon Bedrock".

> **Betreff: In welchen Regionen verarbeiten das EU-Inferenzprofil und das Geländerprofil?**
>
> für unser Konto 579138738703 (Region eu-central-1) bitten wir um eine verbindliche Auskunft, **in welchen Regionen** die folgenden Profile Anfragen verarbeiten:
>
> 1. das EU-Inferenzprofil für die von uns genutzten Modellkennungen, 2. das Geländerprofil `eu.guardrail.v1:0`.
>
> Wir bitten um eine **namentliche Aufzählung der Regionen**. Die Angabe, es handele sich um „EU-Regionen" oder um Regionen mit dem Vorsatz `eu-`, genügt uns nicht: `eu-central-2` liegt in Zürich und `eu-west-2` in London, also außerhalb der Europäischen Union und des Europäischen Wirtschaftsraums.
>
> Hintergrund ist eine Datenschutz-Folgenabschätzung nach Art. 35 DSGVO. Für sie ist erheblich, ob eine Verarbeitung außerhalb der EU und des EWR stattfindet.
>
> **Was in diese Anfrage nicht gehört, und das ist keine Förmelei:** kein Akteninhalt, kein Beispiel, kein Bildschirmfoto mit Text. Nach Ziffer 6.5 der AWS-Kundenvereinbarung überträgt ein „Vorschlag" an AWS diesem unwiderruflich sämtliche Rechte daran. Die Anfrage oben enthält deshalb nichts als Kontonummer, Profilnamen und die Frage.

Was mit der Antwort geschieht — drei Fälle:

1. **Nur Regionen in der EU und im EWR:** Der Satz „Übermittlung in Drittländer findet nicht statt" darf in die Hinweise nach Art. 13 (`DATENSCHUTZHINWEISE-ENTWURF.md`, dort `[KANZLEI 2]`), und R5 fällt auf „gering".
2. **Zürich oder London sind dabei:** Der Satz darf **nicht** hinein. Dann ist zu prüfen, ob sich das Geländerprofil auf EU-Regionen einschränken lässt; wenn nicht, ist der Drittlandbezug in den Hinweisen zu beschreiben und auf Art. 46 zu stützen.
3. **AWS antwortet ausweichend oder gar nicht:** Dann bleibt es bei der heutigen Lage — die Angabe ist ungesichert, R5 bleibt „mittel", und der Satz bleibt draußen. **Bei Dritten wird gewartet, nicht geraten.**

R6 · Besondere Kategorien, verstärkt durch die Texterkennung

Seit dem 02.10.2026 werden auch gescannte Blätter gelesen. Rückscheine und Vollmachten enthalten regelmäßig keine Gesundheitsdaten — ärztliche Unterlagen in einer Arzthaftungssache sehr wohl, und genau die liegen typischerweise als Scan vor.

Die Texterkennung erweitert damit den Umfang der Art.-9-Verarbeitung, ohne dass sich an Anbieter, Region oder Vertrag etwas ändert.

Maßnahme	Stand
Derselbe Auftragsverarbeiter, derselbe AV-Vertrag	kein neuer Vertrag
Nicht gespeichert, nicht zur Verbesserung der Dienste verwendet	**belegt am 14.10.2026** — siehe unten

Maßnahme	Stand
Abschaltbar mit einer Zeile	`JUSPERFECT_OCR=keine`; gescannte Blätter bleiben dann ungelesen

[KANZLEI 12] — Erlaubnistatbestand und die Frage nach dem Rechtsgebiet. Entwurf zur Übernahme, geschrieben am 15.10.2026.

> **Zum Erlaubnistatbestand.** Soweit besondere Kategorien personenbezogener Daten verarbeitet werden, stützt sich die Kanzlei auf **Art. 9 Abs. 2 lit. f DSGVO**: Die Verarbeitung ist zur Geltendmachung, Ausübung oder Verteidigung von Rechtsansprüchen erforderlich. Soweit Daten über strafrechtliche Verurteilungen und Straftaten betroffen sind, beruht die Verarbeitung auf **Art. 10 DSGVO in Verbindung mit § 22 BDSG**. Eine Beschränkung des Programms auf einzelne Rechtsgebiete erfolgt nicht.

Warum lit. f und nicht die Einwilligung. Art. 9 Abs. 2 lit. a verlangt eine **ausdrückliche** Einwilligung und ist jederzeit widerruflich — mitten im Mandat. Lit. f ist nicht widerruflich und beschreibt genau das, was eine Kanzlei tut. Dieselbe Überlegung trägt die Entscheidung gegen eine Einwilligung in den Mandatsbedingungen.

Warum keine Beschränkung nach Rechtsgebiet — und warum ich darüber nachgedacht habe. Es wäre naheliegend, das Programm etwa für Strafsachen oder Arzthaftungssachen zu sperren. Dagegen sprechen drei Dinge:

1. **Die Abgrenzung trüge nicht.** Gesundheitsdaten stehen in der Verkehrsunfallsache so gut wie in der Arzthaftungssache. Eine Sperre nach Rechtsgebiet erzeugt ein Gefühl von Sicherheit, wo keine Grenze verläuft.
2. **Die wirksame Grenze liegt eine Ebene tiefer.** Was zum Modell geht, entscheidet der Haken je Dokument — nicht das Rechtsgebiet. Das ist die Auswahl im Dokumentfenster, und sie steht als Hausregel in der Einweisung.
3. **Eine Sperre, die umgangen werden kann, ist keine.** Das Rechtsgebiet steht in der Akte, nicht im Programm; eine Akte ohne gepflegtes Rechtsgebiet fiele durch jede Sperre hindurch.

> **Was stattdessen trägt:** `JUSPERFECT_OCR=keine` schaltet die Texterkennung ab, wenn die Kanzlei den Umfang der Art.-9-Verarbeitung verkleinern will — eine Zeile, nachvollziehbar, und sie wirkt für alle Akten gleich.
>
> **Berichtigt am 05.10.2026 nach der Zweitprüfung (Befund F12).** Die Unterlagen schlossen aus dem Versand als Bytes **ohne** eigenen S3-Zwischenspeicher, AWS speichere die Bilder nicht. **Dieser Schluss trägt nicht.** Für die KI-Dienste von AWS — anders als für Bedrock — gilt die Nicht-Speicherung nur bei einer wirksamen **AI-services-Opt-out-Richtlinie** des Kontos. Ohne diesen Nachweis ist „nicht gespeichert" eine Vermutung.
> **[KANZLEI 19] — eingelöst am 14.10.2026.** Für das AWS-Konto 579138738703 ist eine **wirksame** Abmelderichtlinie für KI-Services (*AI services opt-out policy*) festgestellt worden. Die Konsole gibt als effektive Richtlinie des Kontos aus:
> ``json { "services": { "default": { "opt_out_policy": "optOut" } } } ``
>
> Festgestellt am **14.10.2026, 17:11 MESZ**; die Richtlinie `jusperfect-keine-ki-nutzung` ist an der Stammorganisation verknüpft, AWS meldet keine

> Validierungsprobleme. Die Bildschirmausdrucke liegen in der Datenschutzakte. **Damit ist belegt:** Inhalte der erfassten KI-Dienste — Textract gehört dazu — werden nicht gespeichert und nicht zur Entwicklung und Verbesserung der AWS-KI-Dienste verwendet.
>
> **Was damit nicht belegt ist, und was deshalb eine eigene Frage bleibt.**
>
> 1. **Bedrock ist von dieser Richtlinienart nicht erfasst.** Die Abmeldung sagt über die Verarbeitung im Modell nichts. AWS führt dafür an, Bedrock verwende Inhalte ohnehin nicht zur Verbesserung der Dienste; eine Auskunft dazu ist beim AWS-Support angefragt (`AWS-ZWEI-HANDGRIFFE.md`, Support-Text, Punkt 3). Bis sie vorliegt, gilt für Bedrock die vertragliche Grundlage und nicht diese Richtlinie. 2. **Die Abmeldung betrifft Speicherung und Verwendung zur Entwicklung und Verbesserung der Dienste** — den Wortlaut der Konsole. Aufbewahrung zu anderen Zwecken, etwa zum Betrieb, hängt am Auftragsverarbeitungsvertrag und nicht hieran.
>
> Abschalten der Texterkennung, falls sie je zu klären ist: `JUSPERFECT_OCR=keine` in `START-JURNODES.bat` — **nicht** `aus`, wie es hier zuvor stand.

[KANZLEI 12] — Erlaubnistatbestand nach Art. 9 Abs. 2 benennen, und bewerten, ob eine Beschränkung nach Rechtsgebiet getroffen werden soll. Das Programm unterscheidet **nicht** nach Rechtsgebiet; eine Beschränkung wäre organisatorisch zu treffen.

> **Was das Schutzgeländer hier ausdrücklich nicht tut:** Es filtert Gewalt, Sexuelles und Beleidigungen **nicht**. Die Voreinstellung von AWS hätte das getan — in einer Kanzlei ist genau das der Gegenstand der Arbeit. Eingeschaltet ist allein die Erkennung von Angriffen über den Fragetext.

R7 · Zugriff innerhalb der Kanzlei

Lage	
Heute	alle eingetragenen Nutzer haben Zugriff auf alle Akten (Stand 24.09.2026)
Technisch möglich	eine Beschränkung je Nutzer auf einzelne Akten; im Programm vorhanden und in den Testdaten benutzt
Die Anmeldung	ist im Laufwerks- und Schnittstellenbetrieb **kein Kennwort**, sondern eine Kennung. Wer am Rechner sitzt, kann eine andere eintragen

~~[KANZLEI 13]~~ — am 15.10.2026 von der Kanzlei entschieden.

Aus der Kanzlei, auf den Vorschlag einer Beschränkung je Bearbeiter:

> „Nein, dafür sind wir zu klein. Jeder darf die Akten des anderen sehen."
>
> **Zum Zugriff innerhalb der Kanzlei.** Die Kanzlei hat geprüft, ob der Zugriff auf einzelne Bearbeiter beschränkt wird, und sieht davon ab. In einer Kanzlei dieser Größe vertritt jede Berufsträgerin und jeder Berufsträger jede andere; eine Beschränkung, die im Vertretungsfall regelmäßig aufgehoben werden müsste, schützt niemanden und erschwert die Mandatsbearbeitung. Alle Personen, die Zugang haben, sind zur Verschwiegenheit verpflichtet; jeder Zugriff wird einer namentlichen Kennung

> zugeordnet. Die Entscheidung wird bei der jährlichen Durchsicht erneut geprüft, insbesondere bei einer Veränderung der Kanzleigröße.

Das ist rechtlich tragfähig, und ich sage auch, warum. Art. 32 DSGVO verlangt Maßnahmen, die dem Risiko **angemessen** sind — nicht die jeweils schärfsten. Angemessenheit hängt am Umfang und an den Umständen. Bei einer Kanzlei, in der die Vertretung der Regelfall und nicht die Ausnahme ist, wäre eine Beschränkung auf die eigene Akte eine Maßnahme, die im Alltag umgangen werden müsste; eine Berechtigung, die regelmäßig überschrieben wird, ist keine.

§ 203 StGB steht dem nicht entgegen. Die Mitarbeitenden einer Kanzlei sind berufsmäßig tätige Gehilfen; die Offenbarung ihnen gegenüber ist keine unbefugte. Entscheidend ist nicht, ob jeder alles **sehen kann**, sondern ob jeder zur Verschwiegenheit **verpflichtet** ist und ob ein Zugriff **zuzuordnen** ist.

Was damit die Last trägt — und es ist jetzt die organisatorische Seite:

Die Verpflichtung auf die Verschwiegenheit	**Liegt vor.** Die Kanzlei hat am 15.10.2026 bestätigt: Jede Mitarbeiterin und jeder Mitarbeiter hat bereits **bei Eintritt** eine Verpflichtungserklärung unterschrieben. Bei Referendaren, Aushilfen und externer IT ist darauf zu achten, dass das ebenso geschieht
Der zweite Faktor	Seit 15.10.2026. Er beantwortet die Frage, die bei offenem Zugriff die wichtigste ist: **wer** zugegriffen hat
Das Windows-Konto	Bildschirmsperre, keine geteilten Konten, jeder trägt seine eigene Kennung ein. Steht als Regel 1b in `EINWEISUNG.md`
Der Nutzungsnachweis	Jeder Eintrag trägt die Kennung. Bei geteilten Konten fällt er aus — deshalb steht das Verbot in der Einweisung

> **Ein Satz, der zu dieser Entscheidung gehört und nicht verschwiegen werden soll:** Sie verlagert den Schutz von der Technik auf die Organisation. Das ist zulässig und bei dieser Größe vernünftig — aber es heißt, dass die Verpflichtungserklärungen und die Bildschirmsperre **nicht optional** sind. Sie sind jetzt die Maßnahme und nicht mehr die Ergänzung.

Zum Zugangsschutz, und hier bin ich deutlicher. Die Anmeldung in jusperfect ist **kein Kennwort, sondern eine Kennung**: Wer am Rechner sitzt, kann eine andere eintragen. Das ist vertretbar, **solange** der Rechner selbst geschützt ist. Es ist nicht mehr vertretbar, sobald ein Arbeitsplatz unbeaufsichtigt entsperrt bleibt oder zwei Personen dasselbe Windows-Konto benutzen.

> **Die Zuordnung im Nachweis hängt daran.** Jeder Nutzungseintrag trägt die eingetragene Kennung. Teilen sich zwei Personen ein Konto, sagt der Nachweis nicht mehr, wer gefragt hat — und damit fällt die Rechenschaftspflicht nach Art. 5 Abs. 2 an dieser Stelle aus.

Seit dem 15.10.2026 gibt es dafür einen zweiten Faktor. Auf Weisung der Kanzlei: *„Ich möchte für die Programmöffnung jusperfect und die Möglichkeit der Einrichtung einer 2-Faktor-Authentifizierung.“*

Ein Einmalkennwort aus einer Authentifizierungs-App (TOTP nach RFC 6238 — dieselbe Technik wie bei AWS und bei der Bank) tritt vor das Programm. Eingeschaltet wird er mit

JUSPERFECT_ZWEITER_FAKTOR=an; voreingestellt ist „aus“, damit eine Kanzlei mit geschütztem Einzelplatz nicht zu einem zweiten Gerät gezwungen wird.

> **Was er leistet und was nicht.** Er ersetzt den Schutz des Windows-Kontos nicht. Er sorgt dafür, dass ein unbeaufsichtigter Rechner allein nicht genügt, um eine Mandatsakte zu öffnen — und dass der Nutzungsnachweis den Richtigen nennt. Die Geheimnisse liegen in einer eigenen Datei, nicht in der Nutzerdatei: Die wird von Hand gepflegt und liegt in der Sicherung.
> `jusperfect/security/zweiter_faktor.py`, 21 Prüfungen in `tests/test_zweiter_faktor.py`.

Drei Dinge, die auch ohne ihn gelten und die ich in die Einweisung aufnehmen würde, wenn die Kanzlei zustimmt:

1. Bildschirmsperre beim Verlassen des Platzes, automatisch nach wenigen Minuten.
2. Keine geteilten Windows-Konten.
3. Jeder trägt seine eigene Kennung ein — auch wer nur kurz nachsieht.

R8 · Auskunft, Berichtigung, Löschung (Art. 15 bis 17)

Verlangen	Wie es bedient wird
Auskunft	Was im Aktengedächtnis liegt, ist in der Oberfläche **im Wortlaut** einsehbar — Lebenssachverhalt, Zeitstrahl, frühere Fragen, mit Fundstellen
Berichtigung	Einzelne Einträge lassen sich entfernen; die Akte in jur\
Löschung	gezielt je Dokument oder je Frage-Antwort-Runde, oder vollständig über den Abschluss
Nachweis der Verarbeitung	der Nachweis nennt Zeitpunkt, Nutzer, Funktion, Modell, Umfang — **ohne Inhalt**

Eine Grenze, die genannt gehört: Was einmal an das Modell übermittelt wurde, lässt sich nicht zurückholen. Mehr als eine vertragliche Schranke gibt es dagegen nicht: AWS darf die Inhalte nur nutzen, soweit zur Erbringung der Services nötig (Kundenvereinbarung Ziffer 1.4 und 6.1). Diese Schranke steht **nicht** im Auftragsverarbeitungsvertrag; die Service Terms gehen ihr vor, weichen für Bedrock aber nicht von ihr ab (R4, Abschnitt 50.12). **Beim Auftragsverarbeiter wird darüber hinaus nichts aufbewahrt:** Die Missbrauchserkennung nach 50.12.2 greift für das eingesetzte Modell nicht (`[KANZLEI 22]`). Bei einem gelisteten Modell läge es anders — dann lägen Ein- und Ausgaben bis zu dreißig Tage bei AWS, und eine Löschung durch die Kanzlei erreichte sie nicht. **[KANZLEI 14] — erledigt am 15.10.2026, bis auf eine Entscheidung.** Der Satz steht jetzt nicht mehr nur im Entwurf, sondern in der Unterlage, die die Mandantschaft erhält: `HINWEISE-DATENVERARBEITUNG.md`, Ziffer 3, zweimal — einmal nüchtern („Die zur Auswertung übermittelten Texte werden dort nicht aufbewahrt") und einmal im freiwilligen Kasten („Was einmal zur Auswertung übermittelt wurde, lässt sich nicht zurückrufen").

Zu entscheiden bleibt nur, ob der Kasten bleibt (dort als `[KANZLEI 4]` geführt). **Mein Rat: behalten.** Er beantwortet die Frage, die Mandanten stellen, bevor sie gestellt wird — und er sagt eine unangenehme Wahrheit, bevor jemand anders sie sagt.

> **Und die Abhängigkeit, die dabei nicht untergehen darf:** Der Satz „wird dort nicht aufbewahrt" ist richtig, **weil** das eingesetzte Modell nicht auf der Missbrauchserkennungsseite steht. Bei einem gelisteten Modell lägen Ein- und Ausgaben bis zu dreißig Tage bei AWS, eine Löschung durch die Kanzlei erreichte sie nicht — und die Hinweise wären unrichtig. Davor schützt Regel 1 der Einweisung.

---

5. Was das Programm von sich aus verweigert

Das gehört in die Bewertung, weil es die Maßnahmen von bloßen Absichten unterscheidet. **Das Programm startet nicht**, wenn mit echten Akten eine dieser Bedingungen nicht erfüllt ist:

- AWS schreibt die Modellaufrufe mit, oder der Zustand ist unbekannt
- kein Schutzgeländer hinterlegt
- kein Schlüssel der Kanzlei bei dauerhafter Ablage
- eine unverschlüsselte Ablage auf dem Rechner zusammen mit echten Akten
- eine Region außerhalb der EU

Das ist keine Warnung, sondern ein Abbruch — geprüft in `tests/test_config.py`.

2.543 automatische Prüfungen halten diese und die übrigen Zusagen (Stand 15.10.2026).

---

6. Organisatorische Maßnahmen — offen

[KANZLEI 15] · Schulung	Entwurf unten
Nutzerverwaltung	siehe R7
Kostengrenze	100 USD im Monat, meldet und bremst nicht
Weitergabe von Befunddateien	Die Prüfprogramme schreiben Dateien ohne Akteninhalt; ein Blick vor dem Weitergeben bleibt vorgesehen

[KANZLEI 15] — die Schulung. Entwurf zur Übernahme, geschrieben am 15.10.2026.
Eine Stunde, dokumentiert; sie erfüllt zugleich die KI-Kompetenz nach **Art. 4 KI-VO**.

	Inhalt	**Dauer**
1	**Was das Programm tut und was nicht.** Es wertet aus und entwirft; es entscheidet nicht, berechnet keine Fristen und versendet nichts	10 min
2	**Die Belegpflicht und ihre Grenze.** Jede Aussage zeigt auf eine Stelle der Akte. Eine Fundstelle sagt, **worauf** ein Satz beruht — **nicht**, dass sie ihn trägt. Das ist der Satz, auf den es ankommt	15 min

	Inhalt	Dauer
3	**Die Auswahl im Dokumentfenster.** Zum Modell geht nur, was angehakt ist. Das ist Datenminimierung nach Art. 5 Abs. 1 lit. c und die wirksamste Maßnahme in der Hand des Bearbeiters	10 min
4	**Die beiden Hausregeln** aus `EINWEISUNG.md`: kein gelistetes Modell, und die Kontoadresse wird gelesen	10 min
5	**Was zu tun ist, wenn etwas auffällt** — eine Aussage ohne Beleg, ein fremdes Dokument, eine Fehlermeldung ohne Grund. Wem es gemeldet wird und dass es gemeldet wird	10 min
6	**Fragen**	5 min

> **Nachweis.** Datum, Dauer, Inhalt in Stichworten, Namen und Unterschriften der Teilnehmenden; ein Blatt zur Datenschutzakte. Die Einweisung (`EINWEISUNG.md`) trägt die Unterschriftenzeilen bereits und kann als dieser Nachweis dienen, wenn die sechs Punkte oben darauf vermerkt werden.

Warum Punkt 2 doppelt so lang ist wie die anderen. Weil dort der Fehler liegt, den das Programm nicht verhindern kann. Ein Satz mit Fundstelle sieht geprüft aus. Er ist es nicht — die Fundstelle sagt nur, aus welcher Stelle der Akte er stammt. Wer das nicht verstanden hat, liest die Belege als Siegel statt als Verweis, und dann arbeitet das Programm gegen ihn.

Art. 4 KI-VO verlangt nicht mehr als das. Die Vorschrift will, dass die Menschen, die ein KI-System bedienen, es hinreichend verstehen, um seine Ergebnisse einzuordnen. Genau das leisten die sechs Punkte — und sie leisten es für diese Kanzlei und dieses Programm, nicht allgemein.

---

7. Verbleibendes Risiko und Konsultation

[KANZLEI 17] — vollständig offen, weil es die Bewertung selbst ist:

1. Wie hoch ist das verbleibende Risiko nach den Maßnahmen?
2. Ist es tragbar, oder ist die Aufsichtsbehörde nach Art. 36 zu konsultieren?
3. Ist der Datenschutzbeauftragte beteiligt worden (Art. 35 Abs. 2)?
4. Wann wird die DSFA überprüft (Art. 35 Abs. 11)?

> **Ein Vorschlag zur vierten Frage, keine Vorgabe:** Die Unterlage ist zu überprüfen, sobald sich eines dieser vier Dinge ändert — ein neuer Auftragsverarbeiter, ein neuer Speicherort, eine neue Übermittlung (die Texterkennung war eine), oder eine Antwort des Herstellers zu R1.

[KANZLEI 17] — der Abschluss. Entwurf zur Übernahme, geschrieben am 15.10.2026, nachgeführt am selben Tag. `[KANZLEI 7]` ist gebaut und `[KANZLEI 13]` entschieden; offen bleibt allein die Auskunft zu `[KANZLEI 11]`, die den Satz zu R5 betrifft.

> **Zum verbleibenden Risiko.** Nach den beschriebenen Maßnahmen hält die Kanzlei das verbleibende Risiko für die Rechte und Freiheiten der betroffenen Personen für **tragbar**. Alle acht bewerteten Risiken stehen nach den Maßnahmen auf „mittel“ oder

> darunter. Ein hohes Risiko im Sinne des **Art. 36 Abs. 1 DSGVO** verbleibt nach Auffassung der Kanzlei nicht; eine vorherige Konsultation der Aufsichtsbehörde erfolgt daher nicht.
>
> **Ein Vorbehalt gehört dazu:** Die Verschwiegenheitsverpflichtung des Auftragsverarbeiters nach § 43e BRAO (`[KANZLEI 9]`) ist einseitig erklärt und nicht gegengezeichnet. Die Kanzlei sieht darin ein hinnehmbares, aber fortbestehendes rechtliches Risiko.
>
> **Datenschutzbeauftragter.** Ein Datenschutzbeauftragter ist nicht benannt, da keine Benennungspflicht besteht; eine Beteiligung nach Art. 35 Abs. 2 DSGVO entfällt.
>
> **Überprüfung (Art. 35 Abs. 11).** Die Folgenabschätzung wird **jährlich** überprüft, erstmals zum TT.MM.JJJJ, und außerdem unverzüglich, sobald eines dieser Ereignisse eintritt: ein neuer Auftragsverarbeiter; ein neuer Speicherort; eine neue Art der Übermittlung; ein Wechsel des eingesetzten Modells; eine Änderung der Nutzungsrichtlinie des Modellanbieters; eine Antwort des Herstellers der Aktenverwaltung zu Risiko R1.

Wo ich mir sicher bin, und wo nicht.

Sicher: dass Art. 36 nicht greift. Die Vorschrift verlangt eine Konsultation nur, wenn trotz der Maßnahmen ein **hohes** Risiko bliebe. Das ist hier nicht die Lage — die Maßnahmen sind nicht Absichtserklärungen, sondern geprüft und zum Teil technisch erzwungen.

Nicht sicher: `[KANZLEI 9]`. Deshalb steht der Vorbehalt im Text und nicht in einer Fußnote. Eine Folgenabschätzung, die ihre schwächste Stelle verschweigt, ist keine Bewertung, sondern eine Werbeschrift.

> **Was diese Stelle entlastet, auch wenn es sie nicht auflöst:** Die Verschwiegenheit im Haus ist lückenlos verpflichtet — jede Person unterschreibt bei Eintritt —, die Datenminimierung begrenzt, was überhaupt hinausgeht, und die Belehrung an den Auftragsverarbeiter ist abgesandt und nachgewiesen. Was bleibt, ist die Frage, ob eine einseitige Erklärung genügt. Das ist eine Rechtsfrage und kein Versäumnis.
>
> **Und ein letzter Punkt zur Reihenfolge:** Dieser Abschluss wird unterschrieben, **nachdem** die Belehrung an AWS abgesandt ist (`[KANZLEI 9]`). Das ist die einzige Maßnahme, auf die er sich stützt und die es noch nicht gibt. Dass für jede Person mit Zugang eine Verpflichtungserklärung vorliegt, hat die Kanzlei am 15.10.2026 bestätigt.

---

8. Die zweiundzwanzig Stellen für die Kanzlei auf einen Blick

Stand 15.10.2026: Zu jeder offenen Stelle liegt ein Entwurf vor. Die Spalte „Stand" sagt, was noch fehlt — eine Entscheidung der Kanzlei, eine Auskunft von Dritten oder eine Arbeit am Programm.

Nr.	Worum es geht	Stand	Abschnitt
1	Ist eine DSFA erforderlich?	**Entwurf: ja.** Nur zu übernehmen	1
2	Ist der Umfang „umfangreich"?	**Entwurf: ja** — und es kommt nicht darauf an	1

Nr.	Worum es geht	Stand	Abschnitt
16	Welche Muster-Liste gilt?	**Hamburg**, nicht-öffentlicher Bereich. Die Liste selbst ist noch aufzurufen	1
3	Verhältnismäßigkeit insgesamt	**Entwurf: verhältnismäßig.** Nur zu übernehmen	3
4	Modell auf eigener Hardware?	**Entwurf: nein**, jährlich neu zu prüfen	3.2
5	Einstufung der acht Risiken	**Entwurf liegt vor** — sieben „mittel" oder darunter, **R7 hoch**	4
~~6~~	~~R1, Art. 4 Nr. 12~~	**Von der Kanzlei entschieden**	R1
7	Wann wird die Fallkopie gelöscht?	**Gebaut am 15.10.2026:** Abschluss + 30 Tage, dazu die Rückfrage „Läuft die Akte noch?“ nach 12 Monaten	R3
8	Ablage des Vertragswerks	Service Terms liegen bei (Anlage 15). **Offen: Standardvertragsklauseln und Unterauftragsverarbeiterliste**	R4
9	Verschwiegenheitsverpflichtung § 43e BRAO	**Die schwächste Stelle.** Das Schreiben liegt seit 15.10.2026 bereit; es ist abzusenden	R4
10	Dienstleisterauswahl § 43e Abs. 2	Nachweise in der Akte, **Bewertung ausformuliert.** Nur zu übernehmen	R4
11	Regionen des Geländerprofils	**Wartet auf AWS.** Der Text der Anfrage steht bereit	R5
12	Art. 9 Abs. 2; Beschränkung nach Rechtsgebiet?	Entwurf: lit. f; **keine** Beschränkung nach Rechtsgebiet	R6
~~13~~	~~Zugriffsbeschränkung je Bearbeiter?~~	**Entschieden am 15.10.2026: keine Beschränkung** — dafür ist die Kanzlei zu klein. Getragen von Verschwiegenheit, zweitem Faktor und Zuordnung	R7
14	Was den Betroffenen gesagt wird	**Erledigt** — steht in den Hinweisen, Ziffer 3	R8
15	Schulung und KI-Kompetenz (Art. 4 KI-VO)	**Entwurf liegt vor** — sechs Punkte, eine Stunde	6
17	Restrisiko, Art. 36, DSB, Überprüfungsfrist	**Entwurf liegt vor.** Zu zeichnen erst nach 7, 11 und 13	7
~~18~~	~~Aktenzeichen und Dokumenttitel an das Modell?~~	**Entschieden am 05.10.2026:** Dateiname nein, Art des Schriftstücks ja, Aktenzeichen nur beim Entwurf	2.1

Nr.	Worum es geht	Stand	Abschnitt
~~19~~	~~Opt-out-Richtlinie für Textract nachweisen~~	**Eingelöst am 14.10.2026, 17:11 MESZ**	R6
~~20~~	~~Bleibt es beim Auftragsverarbeiter?~~	**Entschieden am 14.10.2026: ja**	2.4
~~21~~	~~Service Terms zu Bedrock beschaffen~~	**Gelesen am 14.10.2026**, Ausdruck seit 15.10.2026 (Anlage 15)	R4
22	Missbrauchserkennung nach 50.12.2	**Geklärt am 14.10.2026.** Bleibt: die jährliche Durchsicht der Liste	R4

Was davon wirklich noch Arbeit ist

Drei Dinge, und nur drei:

1. **`[KANZLEI 9]` — die Belehrung an AWS.** Das Schreiben ist seit dem 15.10.2026 aufgesetzt (`BELEHRUNG-AWS.md`). Zu tun bleibt: absenden, den Nachweis ablegen, hier das Datum eintragen.

Die Verpflichtungserklärungen liegen vor — am 15.10.2026 von der Kanzlei bestätigt: Jede Mitarbeiterin und jeder Mitarbeiter unterschreibt sie bereits bei Eintritt. Damit steht die Maßnahme, die seit der Entscheidung zu `[KANZLEI 13]` die tragende ist.

`[KANZLEI 7]` und `[KANZLEI 13]` sind am 15.10.2026 erledigt — die eine gebaut, die andere entschieden.

Zwei warten auf Dritte: die Auskunft von AWS zum Geländerprofil (`[KANZLEI 11]`) und die Hamburger Muss-Liste (`[KANZLEI 16]`).

Alles Übrige ist Lesen und Zeichnen.

Woher die Angaben stammen

Quelle	Inhalt
`DSFA-ANGABEN.md`	alle technischen Werte, mit Datum und Fundstelle
`VERARBEITUNGSVERZEICHNIS-ENTWURF.md`	die Beschreibung nach Art. 30
`SICHERHEIT.md`	die 16 Grundsätze und das Löschkonzept
`MORGEN.md`	der Befund zum Korrespondenzordner vom 05.10.2026
`infra/IAM.md`	die Zugriffsrichtlinie im Wortlaut
`BELEHRUNG-AWS.md`	das Schreiben nach § 43e BRAO nebst Anleitung — `[KANZLEI 9]`

Quelle	Inhalt
Anthropic, „Usage Policy"	die Bedingung des Modellanbieters, auf die Service Terms 50.12.1 verweist. Vorgelegt am 15.10.2026 in der Fassung mit Wirkung zum **12.11.2026**; die geltende steht unter `anthropic.com/legal/aup`

Bei Widerspruch gilt `DSFA-ANGABEN.md` — dort steht, was gemessen wurde, und an welchem Tag.

Dieser Entwurf ist keine Rechtsberatung.